Universidad Politécnica de San Luis Potosí

Informe Seguridad Ofensiva

Presentado por:

Christian Alfredo Morales Meza – 184937

Asignatura: CNO IV Seguridad Informática

Profesor: Servando López Contreras

Fecha de entrega: 13/10/2026

Índice de contenido

Índice de contenido 2
1. Alcance y Metodología 8
1.1 Objetivo del ejercicio 8
1.2 Alcance del entorno evaluado 8
1.3 Metodología de evaluación 8
1.4 Herramientas utilizadas 9
1.5 Reglas del ejercicio y limitaciones 10
2. Resumen Ejecutivo 10
3. Inventario de Vulnerabilidades 12
4. Hallazgos Detallados 15
Hallazgo RT-01: Exposición de artefacto de despliegue mediante listado de directorio 15
Comprobación y procedimiento de explotación 15
Causa raíz 16
Impacto y riesgo 17
Evidencia / bandera obtenida 17
Mitigación recomendada 17
Hallazgo RT-02: Exposición de token de validación mediante endpoint de metadatos de build 18
Comprobación y procedimiento de explotación 18
Causa raíz 19
Impacto y riesgo 19
Evidencia / bandera obtenida 19
Mitigación recomendada 20

Hallazgo RT-03: Referencia Directa a Objetos Insegura (IDOR) en múltiples endpoints del Portal Ciudadano 20
Comprobación y procedimiento de explotación 20
Causa raíz 21
Impacto y riesgo 22
Evidencia / bandera obtenida 22
Mitigación recomendada 22
Hallazgo RT-04: Exposición de código fuente mediante archivo de respaldo residual 23
Comprobación y procedimiento de explotación 23
Causa raíz 25
Impacto y riesgo 25
Evidencia / bandera obtenida 26
Mitigación recomendada 26
Hallazgo RT-05: Divulgación de información mediante manejo inadecuado de excepciones en exportar.php 27
Comprobación y procedimiento de explotación 27
Causa raíz 28
Impacto y riesgo 28
Evidencia / bandera obtenida 28
Mitigación recomendada 29
Hallazgo RT-06: Escalamiento de privilegios verticales mediante cookie de rol controlada por el cliente 29
Comprobación y procedimiento de explotación 29
Causa raíz 31
Impacto y riesgo 31
Evidencia / bandera obtenida 31

Mitigación recomendada 32

Hallazgo RT-07: Inyección SQL ciega basada en booleanos en validador de referencias de licitación 32

Comprobación y procedimiento de explotación 33

Causa raíz 34

Impacto y riesgo 34

Evidencia / bandera obtenida 35

Mitigación recomendada 35

Hallazgo RT-08: Cross-Site Scripting Almacenado (Stored XSS) en campo de descripción de reportes ciudadanos 36

Comprobación y procedimiento de explotación 36

Causa raíz 37

Impacto y riesgo 37

Evidencia / bandera obtenida 38

Mitigación recomendada 38

Hallazgo RT-09: Path Traversal en función de descarga de documentos ciudadanos 39

Comprobación y procedimiento de explotación 39

Causa raíz 40

Impacto y riesgo 40

Evidencia / bandera obtenida 41

Mitigación recomendada 41

Hallazgo RT-10: Fijación de Sesión (Session Fixation) por ausencia de regeneración de identificador al autenticar 41

Comprobación y procedimiento de explotación 41

Causa raíz 43

Impacto y riesgo 43

Evidencia / bandera obtenida 43

Mitigación recomendada 44

Hallazgo RT-11: Gestión Inadecuada de Inventario de API – Endpoint No Documentado de Historial de Servicio 44

Comprobación y procedimiento de explotación 44

Causa raíz 46

Impacto y riesgo 46

Evidencia / bandera obtenida 46

Mitigación recomendada 46

Hallazgo RT-12: Autorización Rota a Nivel de Objeto (BOLA) – Acceso Cruzado entre Cuentas vía Parámetro account 47

Comprobación y procedimiento de explotación 47

Causa raíz 48

Impacto y riesgo 48

Evidencia / bandera obtenida 49

Mitigación recomendada 49

Hallazgo RT-13: Abuso de Lógica de Negocio en Flujo de Pago por Ausencia de Revalidación del Importe 49

Comprobación y procedimiento de explotación 50

Causa raíz 51

Impacto y riesgo 51

Evidencia / bandera obtenida 51

Mitigación recomendada 52

Hallazgo RT-14: Validación Insuficiente de Relación Contrato-Proveedor (Broken Object-Level Relationship Authorization) 52

Comprobación y procedimiento de explotación 52

Causa raíz 54
Impacto y riesgo 54
Evidencia / bandera obtenida 55
Mitigación recomendada 55
Hallazgo RT-15: Exposición de metadatos de diagnóstico en endpoint de estado de infraestructura 55
Comprobación y procedimiento de explotación 55
Causa raíz 56
Impacto y riesgo 57
Evidencia / bandera obtenida 57
Mitigación recomendada 57
Hallazgo RT-16: Bypass de control de acceso mediante falsificación de X-Forwarded-For (IP Spoofing) 58
Comprobación y procedimiento de explotación 58
Causa raíz 59
Impacto y riesgo 60
Evidencia / bandera obtenida 60
Mitigación recomendada 60
Hallazgo RT-17: Autenticación faltante en servicio de telemetría del HMI 61
Comprobación y procedimiento de explotación 61
Causa raíz 63
Impacto y riesgo 63
Evidencia / bandera obtenida 64
Mitigación recomendada 64
Hallazgo RT-18: Verificación insuficiente de autenticidad en el canal de actualización de firmware 64

Comprobación y procedimiento de explotación....65
Causa raíz....67
Impacto y riesgo....67
Evidencia / bandera obtenida....67
Mitigación recomendada....68
Hallazgo RT-19: Ausencia de límite de autorización en la cadena de dependencias de activos69
Comprobación y procedimiento de explotación....69
Captura del proceso seguido. 70
Causa raíz....71
Impacto y riesgo....71
Evidencia / bandera obtenida....72
Mitigación recomendada....72
Hallazgo RT-20: Carga de firmware sin validación de límites operacionales de ingeniería 73
Comprobación y procedimiento de explotación....73
Causa raíz....75
Impacto y riesgo....75
Evidencia / bandera obtenida....76
Mitigación recomendada....76
5. Cadena de Ataque....76
5.1 Cadena de reconocimiento y escalamiento en el portal web/API (RT-01 → RT-14)....76
5.2 Cadena de compromiso del entorno OT/ICS (RT-15 → RT-20)....77
6. Conclusiones Generales y Recomendaciones Prioritarias....78
6.1 Postura de seguridad general....78
6.2 Recomendaciones prioritarias (quick wins) 79
6.3 Recomendación estratégica....79

1. Alcance y Metodología

1.1 Objetivo del ejercicio

El presente informe documenta los resultados de un ejercicio de pentesting de caja gris realizado sobre el Portal INTERAFAS (entorno de laboratorio académico simulado, http://localhost:8080), con el objetivo de identificar, comprobar y documentar vulnerabilidades de seguridad en el portal web ciudadano, su capa de API y el entorno de tecnología operacional (OT/ICS) con el que se integra, evaluando su impacto sobre la confidencialidad, integridad y disponibilidad de la información y de los procesos industriales simulados, y proponiendo medidas de mitigación alineadas a estándares reconocidos (OWASP Top 10, OWASP API Security Top 10, CWE, NIST SP 800-82/800-193 y MITRE ATT&CK for ICS).

1.2 Alcance del entorno evaluado

El alcance comprendió los siguientes componentes del laboratorio, todos ellos expuestos bajo el dominio localhost:8080:

- Portal público INTERAFAS (servicios de agua, alcantarillado, saneamiento y resiliencia): módulos de ciudadanía, contratos, transparencia, pagos y reportes.
- Capa de API del portal (/api/*), consumida por el frontend para alimentar paneles de cuenta, facturación e infraestructura.
- Centro de Operaciones / HMI industrial (/operations/*), incluyendo el gateway de acceso a la zona operacional OPS-NET-20, la consola de telemetría, el canal de actualización de firmware y el panel de contexto de activos.
- Artefactos de despliegue y metadatos de build expuestos públicamente (rutas bajo /assets/).

1.3 Metodología de evaluación

Se siguió un enfoque de caja gris, combinando reconocimiento pasivo y activo, análisis manual y herramientas automatizadas, alineado conceptualmente con el OWASP Web Security Testing Guide (WSTG) y el OWASP API Security Top 10, en las siguientes fases:

- Reconocimiento: revisión de robots.txt, mapeo de superficie con Burp Suite (Target → Site map), análisis del código fuente y JavaScript entregado al cliente, y enumeración de rutas y archivos residuales mediante Burp Intruder.
- Análisis de autenticación y gestión de sesión: inspección de cookies, cabeceras y comportamiento del servidor ante cambios de estado de autenticación.
- Pruebas de control de acceso: verificación de autorización a nivel de objeto (IDOR/BOLA) y de función (escalamiento de privilegios), siguiendo el principio de "autenticación ≠ autorización".
- Pruebas de inyección: inyección SQL ciega basada en booleanos (confirmación manual y explotación automatizada con sqlmap).
- Pruebas de lógica de negocio: interceptación y modificación de parámetros críticos (montos, vínculos contractuales) con Burp Suite Repeater/Intercept.
- Pivote hacia el entorno OT/ICS: explotación de la fuga de metadatos de infraestructura, bypass de segmentación de red (X-Forwarded-For), acceso no autenticado a telemetría, cracking offline de credenciales heredadas (Hashcat) y abuso del canal de actualización de firmware.

1.4 Herramientas utilizadas

- Burp Suite Community Edition (proxy, Intruder, Repeater, Intercept) para interceptación y manipulación de peticiones HTTP.
- sqlmap para automatización de la explotación de inyección SQL ciega.
- Hashcat v7.1.2 para el cracking offline de un verificador SHA-1 heredado.
- Herramientas de desarrollador nativas del navegador (DevTools: Network, Application/Almacenamiento, consola) para inspección de tráfico, cookies y JavaScript del cliente.
- Navegadores independientes (para simular clientes distintos en las pruebas de fijación de sesión).

1.5 Reglas del ejercicio y limitaciones

- Todas las pruebas se realizaron exclusivamente contra el entorno de laboratorio proporcionado para la actividad académica (localhost:8080), sin afectar sistemas de terceros.
- No se ejecutaron ataques de denegación de servicio ni pruebas destructivas fuera de las condiciones simuladas y reversibles del laboratorio (incluyendo el escenario de "estado catastrófico" del Hallazgo 20, generado de forma controlada dentro del simulador OT).
- Las credenciales, tokens y datos personales observados (nombres, CURP, correos) corresponden a datos sintéticos del entorno de pruebas.

2. Resumen Ejecutivo

El ejercicio de pentesting realizado sobre el Portal INTERAFAS permitió identificar y comprobar 20 hallazgos de seguridad que, en conjunto, revelan una postura de seguridad deficiente a lo largo de toda la cadena de valor del sistema: desde el proceso de despliegue y la higiene de artefactos de CI/CD, pasando por el control de acceso y la validación de entrada del portal ciudadano y su API, hasta la segmentación de red y los controles de autenticidad del entorno de tecnología operacional (OT/ICS) que gobierna un proceso industrial simulado de suministro de agua.

La evolución del incidente, reconstruida a partir de los 20 retos resueltos, muestra un patrón consistente: los primeros hallazgos (RT-01, RT-02, RT-04, RT-05 y RT-15) corresponden a fugas de información aparentemente menores —artefactos de despliegue, metadatos de build, archivos de respaldo, mensajes de error y campos de diagnóstico no utilizados por la interfaz— que, sin embargo, proporcionan a un atacante prácticamente todo el reconocimiento necesario para dirigir ataques posteriores de mayor impacto: nombres internos de servicios, rutas de API, estructura de la base de datos y, de forma crítica, la topología de la red operacional (zona OPS-NET-20, segmento 10.40.20.0/24 y la ruta del gateway OT).

Sobre esa base de reconocimiento, el portal ciudadano y su API exhiben fallas sistemáticas de control de acceso: referencias directas a objetos inseguras (RT-03, RT-12) que exponen datos personales sensibles (incluyendo CURP) e historiales financieros de cualquier ciudadano registrado, un escalamiento de privilegios verticales trivial mediante una cookie de rol no firmada

(RT-06), una inyección SQL ciega que permite extraer la base de datos completa sin autenticación (RT-07), un Cross-Site Scripting almacenado que compromete a cualquier visitante de un reporte ciudadano (RT-08), lectura arbitraria de archivos del sistema operativo (RT-09), fijación de sesión que permite secuestrar cuentas sin robar credenciales (RT-10), y dos fallas de lógica de negocio que permiten liquidar adeudos fraudulentamente y falsificar relaciones contractuales (RT-13, RT-14).

El hallazgo de mayor relevancia estratégica para la organización es la cadena continua que conecta los retos RT-15 a RT-20: una fuga de metadatos de diagnóstico revela la topología de la red operacional; un control de acceso basado en un encabezado HTTP falsificable (X-Forwarded-For) permite evadir por completo la segmentación entre la red web y la red OT; el servicio de telemetría del HMI no exige autenticación de sesión propia; el canal de actualización de firmware valida la integridad de los paquetes pero nunca su autenticidad, lo que, combinado con el cracking de una credencial heredada, permite instalar firmware no autorizado; la sesión de mantenimiento resultante carece de límites de autorización sobre la topología de activos; y, finalmente, el propio canal de firmware acepta sin validación un parámetro operacional crítico (la presión de consigna), lo que permite provocar de forma remota una condición catastrófica simulada sobre el proceso industrial. Esta cadena demuestra, de principio a fin, cómo una sucesión de fallas individualmente moderadas puede converger en un impacto físico real sobre infraestructura crítica.

La causa raíz transversal identificada en la mayoría de los hallazgos no es la ausencia de controles de seguridad, sino la confianza excesiva en datos y decisiones del lado del cliente (cookies de rol, campos de formulario deshabilitados, encabezados HTTP de proxy) sin revalidación equivalente en el servidor, combinada con una práctica de higiene de release y gestión de inventario de endpoints insuficiente. Se recomienda, como conclusión principal, que la remediación no se aborde hallazgo por hallazgo de forma aislada, sino mediante una revisión integral de los controles de autorización server-side y del proceso de despliegue, en línea con un programa de gobernanza de seguridad de la información conforme a ISO/IEC 27001.

3. Inventario de Vulnerabilidades

La siguiente tabla maestra resume los 20 hallazgos identificados durante el ejercicio, indicando el identificador asignado, una descripción breve, el componente o endpoint afectado, la categoría de la vulnerabilidad, la severidad estimada y el resultado (bandera) obtenido como evidencia de explotación exitosa.

ID	Hallazgo	Componente / Endpoint afectado	Categoría	Severidad	Resultado (bandera)
RT-01	Exposición de artefacto de despliegue mediante listado de directorio	/assets/docs/public/revision/	Exposición de información	**Alta**	UPSLP_CNOIV-OPEN-DOOR-01
RT-02	Exposición de token de validación mediante endpoint de metadatos de build	/assets/meta/build-manifest.php	Exposición de información (CI/CD)	**Media**	UPSLP_CNOIV-LOOK-CLOSER-02
RT-03	Referencia Directa a Objetos Insegura (IDOR) en múltiples endpoints del Portal Ciudadano	expediente.php, facturacion.php, pago.php, /api/service-history.php	Broken Access Control (IDOR)	**Crítica**	UPSLP_CNOIV-NOT-YOURS-03
RT-04	Exposición de código fuente mediante archivo de respaldo residual	transparencia.php.bak	Security	**Alta**	UPSLP_CNOIV-OLD-MEMORIES-04
RT-05	Divulgación de información mediante manejo inadecuado de excepciones en exportar.php	exportar.php	Manejo inadecuado de errores	**Media**	UPSLP_CNOIV-TOO-MUCH-INFO-05
RT-06	Escalamiento de privilegios verticales mediante cookie de rol controlada por el cliente	gestion-proveedores.php	Escalamiento de privilegios (Broken Access Control)	**Crítica**	UPSLP_CNOIV-WRONG-ROLE-06

ID	Hallazgo	Componente / Endpoint afectado	Categoría	Severidad	Resultado (bandera)
RT-07	Inyección SQL ciega basada en booleanos en validador de referencias de licitación	validar-referencia.php	Inyección SQL	**Crítica**	UPSLP_CNOIV-SILENT-ANSWER-07
RT-08	Cross-Site Scripting Almacenado (Stored XSS) en campo de descripción de reportes ciudadanos	reportes.php (inyección) / seguimiento-reporte.php?id=X (ejecución)	Cross-Site Scripting almacenado	**Alta**	UPSLP_CNOIV-STORED-WORDS-08
RT-09	Path Traversal en función de descarga de documentos ciudadanos	descargar-documento.php	Path Traversal	**Crítica**	UPSLP_CNOIV-TOO-DEEP-09
RT-10	Fijación de Sesión (Session Fixation) por ausencia de regeneración de identificador al autenticar	login.php / perfil.php	Gestión de sesión (Session Fixation)	**Alta**	UPSLP_CNOIV-WHO-ARE-YOU-10
RT-11	Gestión Inadecuada de Inventario de API – Endpoint No Documentado de Historial de Servicio	/api/account-context.php, /api/service-history.php	Gestión de inventario de API	**Media**	UPSLP_CNOIV-HIDDEN-HISTORY-11
RT-12	Autorización Rota a Nivel de Objeto (BOLA) – Acceso Cruzado entre Cuentas vía Parámetro account	/api/service-history.php?account=	Broken Object Level Authorization (API)	**Crítica**	UPSLP_CNOIV-SECOND-ACCOUNT-12
RT-13	Abuso de Lógica de Negocio en Flujo de Pago por Ausencia de Revalidación del Importe	pago.php	Abuso de lógica de negocio	**Alta**	UPSLP_CNOIV-PAYMENT-PATH-13

ID	Hallazgo	Componente / Endpoint afectado	Categoría	Severidad	Resultado (bandera)
RT-14	Validación Insuficiente de Relación Contrato-Proveedor (Broken Object-Level Relationship Authorization)	validar-vinculo.php	Autorización de relación entre objetos	**Media**	UPSLP_CNOIV-TRUSTED-SUPPLIER-14
RT-15	Exposición de metadatos de diagnóstico en endpoint de estado de infraestructura	/api/infrastructure-status.php	Exposición de metadatos de diagnóstico	**Media**	UPSLP_CNOIV-BEHIND-THE-DESK-15
RT-16	Bypass de control de acceso mediante falsificación de X-Forwarded-For (IP Spoofing)	/operations/gateway.php	Bypass de control de acceso (red)	**Crítica**	UPSLP_CNOIV-BEYOND-THE-WEB-16
RT-17	Autenticación faltante en servicio de telemetría del HMI	/operations/telemetry.php	Autenticación faltante	**Crítica**	UPSLP_CNOIV-EYES-ON-THE-PLANT-17
RT-18	Verificación insuficiente de autenticidad en el canal de actualización de firmware	/operations/updates/manifest.php, package.php, install.php	Verificación insuficiente de autenticidad (firmware)	**Crítica**	UPSLP_CNOIV-TRUST-THE-PACKAGE-18
RT-19	Ausencia de límite de autorización en la cadena de dependencias de activos	/operations/asset-context.php?asset=	Exceso de privilegio / Missing Authorization	**Alta**	UPSLP_CNOIV-CHAIN-REACTION-19
RT-20	Carga de firmware sin validación de límites operacionales de ingeniería	/operations/firmware.php	Validación insuficiente de parámetros operacionales	**Crítica**	UPSLP_CNOIV-NOW-YOU-CONTROL-20

4. Hallazgos Detallados

A continuación, se documenta cada hallazgo de forma individual, incluyendo su clasificación, el procedimiento de comprobación seguido, la evidencia técnica recabada, la causa raíz identificada, el impacto y riesgo asociado, y la mitigación recomendada.

Hallazgo RT-01: Exposición de artefacto de despliegue mediante listado de directorio

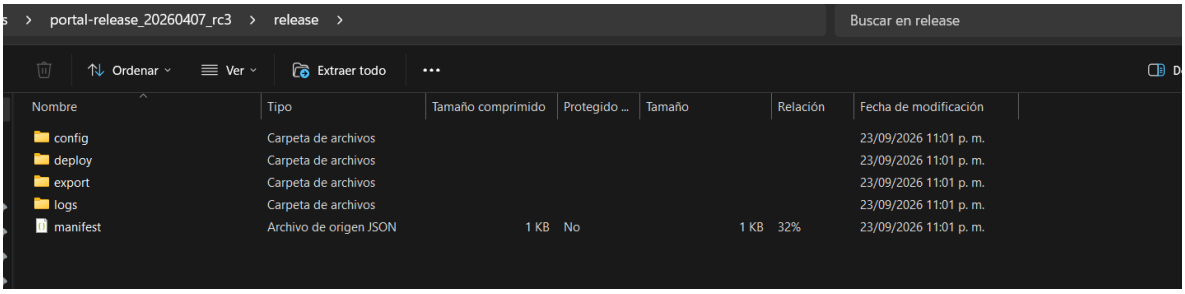
Clasificación	Exposición de información sensible (Information Disclosure) / Configuración insegura del servidor
CWE	CWE-538: Insertion of Sensitive Information into Externally-Accessible File or Directory
Referencia OWASP / estándar	OWASP A05:2021 – Security
Componente / endpoint	/assets/docs/public/revision/
Severidad	Alta
Dónde se encontró	http://localhost:8080/assets/docs/public/revision/

Comprobación y procedimiento de explotación

1. Se revisó el archivo robots.txt del Portal INTERAFAS, práctica estándar de reconocimiento inicial. Este archivo, pensado para indicar a los buscadores qué rutas no indexar, reveló sin querer la existencia de la ruta /assets/docs/public/revision/.
2. Al visitar esa ruta directamente, el servidor Apache (versión 2.4.68) respondió con un listado de directorio habilitado (directory listing), en lugar de bloquear el acceso o mostrar un error 403.



3. Dentro del listado se encontraba el archivo portal-release_20260407_rc3.zip, correspondiente a un paquete de despliegue de la versión candidata del portal.



4. Al extraer el ZIP se hallaron archivos internos del proceso de despliegue: logs de sincronización (rsync), un README-deploy con notas del equipo de operaciones, un manifest.json, un archivo de configuración (config.ini) y un archivo de entorno (release-check.env) que contenía un token de prueba (SMOKE_TEST_TOKEN).

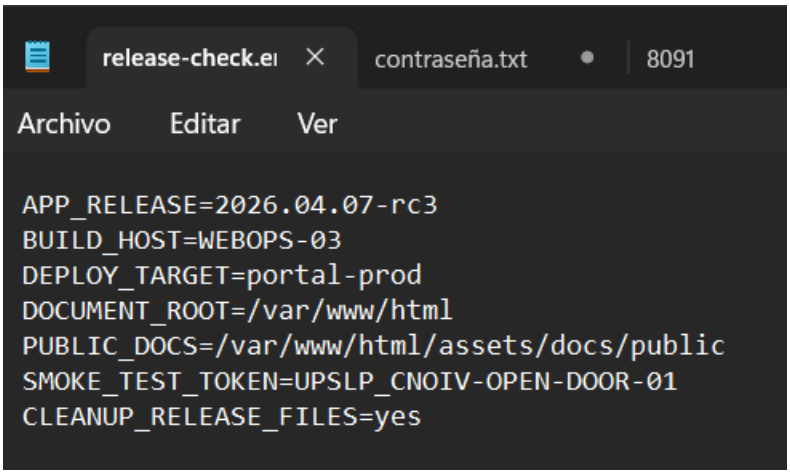
Causa raíz

El propio archivo de configuración del despliegue (release-check.env) contenía las banderas CLEANUP_RELEASE_FILES=yes y remove_release_artifacts=true, confirmando que el proceso de limpieza posterior al despliegue estaba definido pero no se ejecutó correctamente sobre el servidor de producción. El README-deploy lo corrobora explícitamente, dejando constancia de un paso pendiente ("eliminar el archivo de respaldo") que nunca se completó.

Impacto y riesgo

- Divulgación de información interna de infraestructura: nombre del host de build (WEBOPS-03), rutas absolutas del document root, responsable del despliegue (webops) y arquitectura de componentes internos (payments-ui, press-assets, citizen_portal).
- Confirmación de que existen más superficies de ataque no documentadas públicamente (módulo de pagos, portal ciudadano) que ahora se sabe que están activas.

Evidencia / bandera obtenida



Mitigación recomendada

- Deshabilitar el listado de directorios en la configuración de Apache (Options -Indexes).
- Automatizar y verificar, mediante una prueba post-despliegue, que los artefactos de build (.zip, logs, manifest) se eliminen del document root antes de marcar el despliegue como completo.
- Nunca incluir tokens o secretos, ni siquiera "de prueba", dentro de paquetes de despliegue que puedan quedar accesibles públicamente.
- Revisar robots.txt periódicamente para asegurar que no esté exponiendo rutas sensibles por descuido.

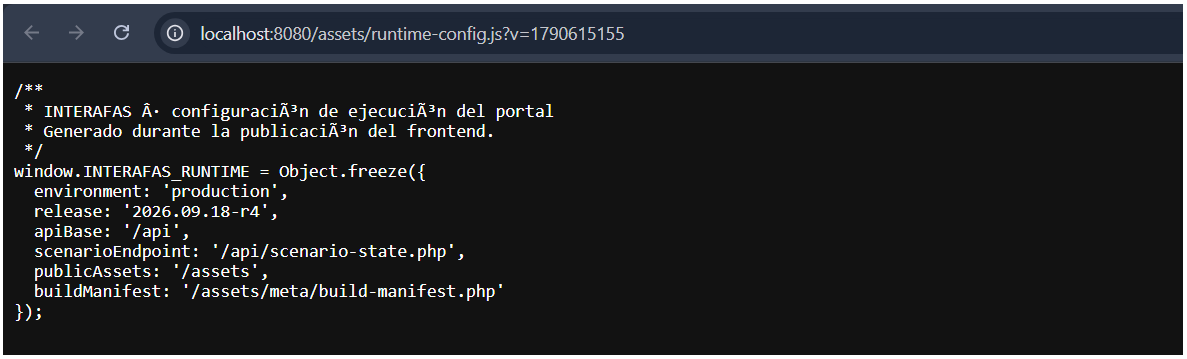
Hallazgo RT-02: Exposición de token de validación mediante endpoint de metadatos de build

Clasificación	Exposición de información sensible (Information Disclosure) / Metadatos de CI-CD expuestos públicamente
CWE	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
Referencia OWASP / estándar	OWASP A05:2021 – Security Misconfiguration
Componente / endpoint	/assets/meta/build-manifest.php
Severidad	Media
Dónde se encontró	http://localhost:8080/assets/meta/build-manifest.php

Comprobación y procedimiento de explotación

1. Al inspeccionar los recursos que recibe el navegador del Portal INTERAFAS más allá de lo visible en pantalla, se identificó un bloque JavaScript inyectado en la página (window.INTERAFAS_RUNTIME) que declara explícitamente la ruta buildManifest: '/assets/meta/build-manifest.php'.





2. Ese objeto es configuración de runtime del frontend, pero contiene una ruta pensada para verificación interna del proceso de build (CI/CD), no para uso del navegador del visitante.
3. A visitar esa ruta directamente, el servidor respondió sin ningún control de acceso con un JSON que incluye el campo quality_assurance.release_validation_token, un token interno de validación de la release.

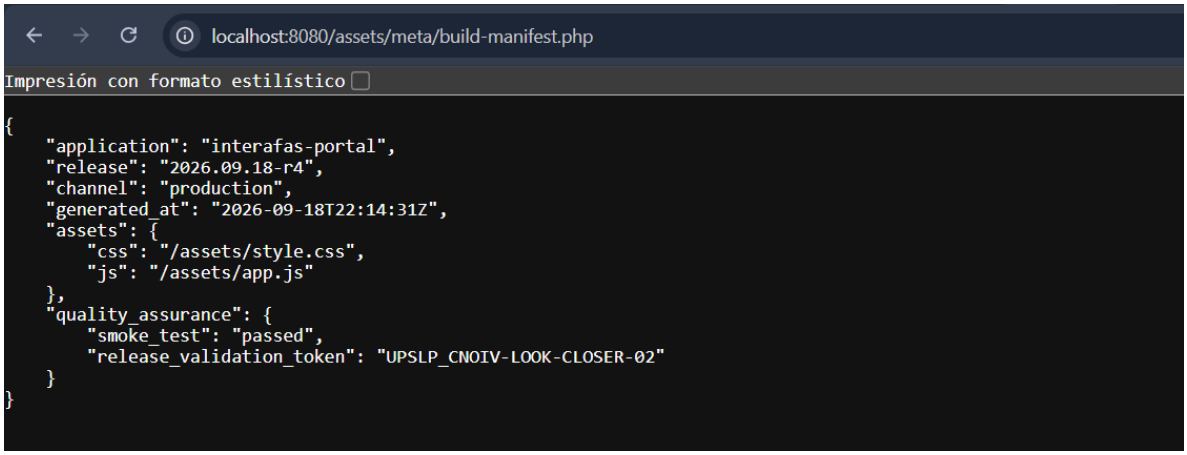
Causa raíz

El equipo de desarrollo dejó un endpoint de metadatos de build accesible públicamente y sin autenticación, y además referenció su ruta directamente en el JavaScript entregado a cualquier visitante: el propio frontend anuncia la ruta, eliminando la necesidad de adivinarla.

Impacto y riesgo

- Divulgación de información interna del pipeline de despliegue (versión de release, canal, fecha de generación, resultado de pruebas de humo).
- Exposición de un token de validación que, de reutilizarse en un sistema real como credencial o parte de un flujo de autorización automatizado, podría dar pie a suplantación de resultados de QA.
- Patrón recurrente: es el segundo token interno expuesto en el mismo sistema (el primero fue el SMOKE_TEST_TOKEN del hallazgo 1), evidencia de una práctica sistémica deficiente de higiene de release.

Evidencia / bandera obtenida



Mitigación recomendada

- Eliminar del bundle de JavaScript público cualquier referencia a rutas o endpoints internos que no sean estrictamente necesarios para el funcionamiento de la interfaz.
- Restringir el acceso a endpoints de metadatos de build (/assets/meta/*) mediante autenticación, lista blanca de IPs internas, o eliminarlos del servidor de producción tras el despliegue.
- No incluir tokens de validación de calidad/smoke test en ninguna respuesta accesible desde fuera de la red de CI/CD.

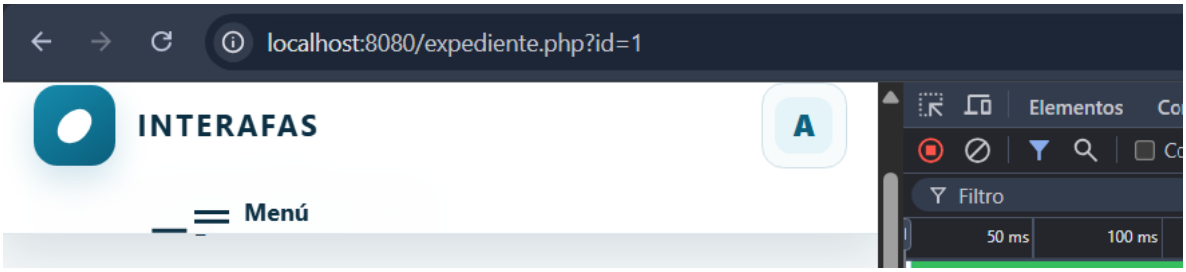
Hallazgo RT-03: Referencia Directa a Objetos Insegura (IDOR) en múltiples endpoints del Portal Ciudadano

Clasificación	Broken Access Control – Insecure Direct Object References (IDOR) / Autorización a nivel de objeto no aplicada
CWE	CWE-639: Authorization Bypass Through User-Controlled Key
Referencia OWASP / estándar	OWASP API3:2023 – Broken Object Level Authorization
Componente / endpoint	expediente.php, facturacion.php, pago.php, /api/service-history.php
Severidad	Crítica
Dónde se encontró	http://localhost:8080/expediente.php?id=2 (y de forma equivalente en facturacion.php?cuenta=, pago.php?cuenta= y /api/service-history.php?account=)

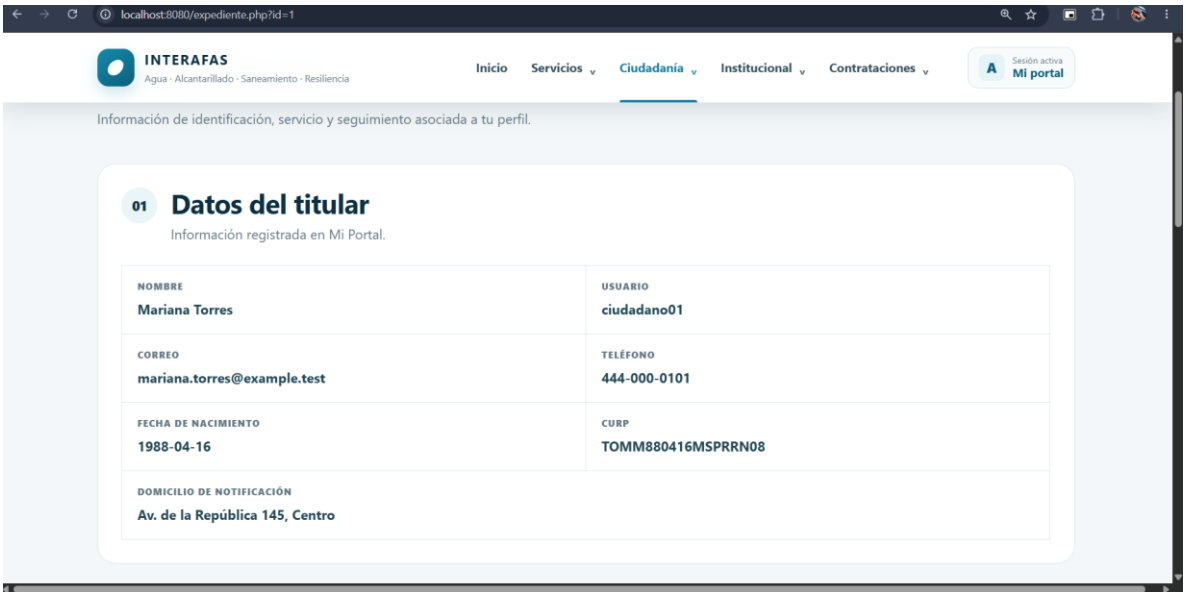
Comprobación y procedimiento de explotación

1. Al consultar el propio expediente (expediente.php) estando autenticado (cookie de sesión PHPSESSID activa), se observó que el identificador de usuario viaja como parámetro id en la URL.

2. Se modificó manualmente ese identificador a ?id=1, sin ninguna otra modificación a la sesión ni credenciales adicionales.



3. El servidor respondió, sin validar que el expediente perteneciera al usuario autenticado, con el expediente completo de un tercero (nombre, usuario, correo, teléfono, fecha de nacimiento, CURP y domicilio de notificación).



4. Al repetir la prueba con ?id=2, se obtuvo el expediente de otra persona distinta con la misma estructura de datos, confirmando que el fallo es sistemático y enumerable, no un error puntual de un solo registro.

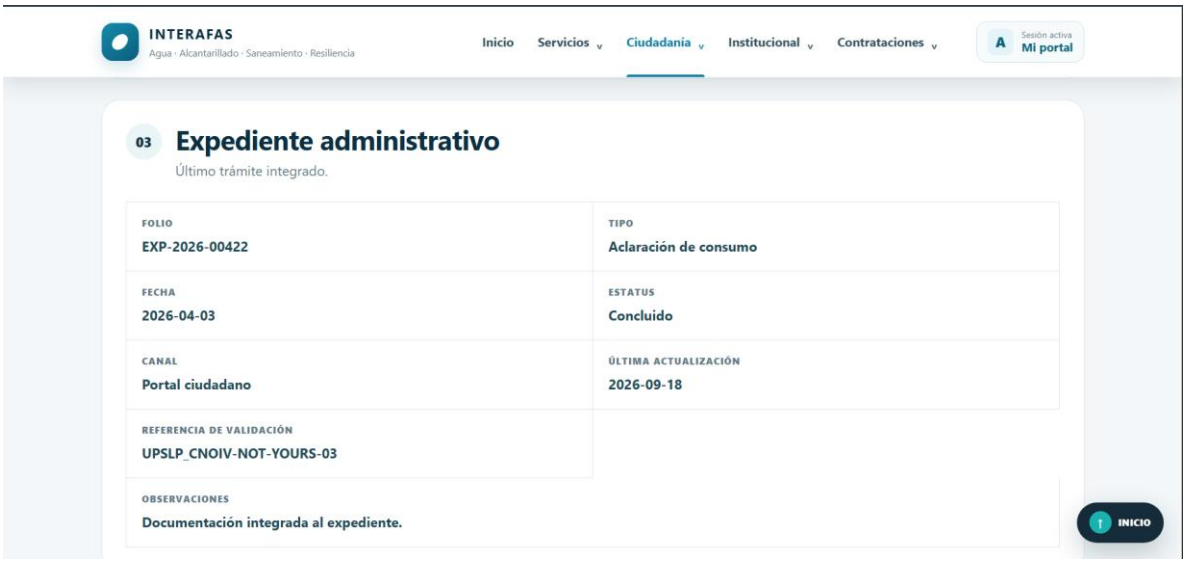
Causa raíz

El sistema valida correctamente la autenticación (sabe que hay una sesión activa y legítima), pero no implementa autorización a nivel de objeto: nunca comprueba que el id del expediente solicitado corresponda al usuario dueño de esa sesión. El servidor confía ciegamente en el valor que el cliente envía en la URL.

Impacto y riesgo

- Exposición masiva de datos personales sensibles (PII), incluyendo CURP, de cualquier ciudadano registrado en el sistema.
- Enumeración trivial: al ser el identificador secuencial, un atacante puede recorrer automáticamente todo el padrón de usuarios y extraer sus datos completos en minutos.
- Al combinarse con facturacion.php y pago.php (mismo patrón, mismo parámetro vulnerable), el atacante obtiene también historial financiero asociado a cada persona.
- Riesgo reputacional y legal para la organización por fuga de datos personales a cualquier usuario con una cuenta básica del portal.

Evidencia / bandera obtenida



Mitigación recomendada

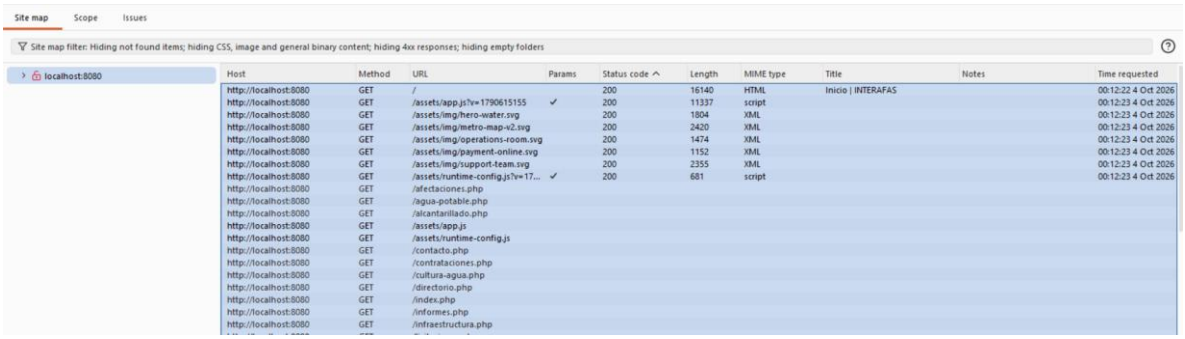
- Antes de devolver cualquier expediente, verificar en el backend que el id solicitado coincide con el usuario de la sesión activa (o que el solicitante tiene un rol explícitamente autorizado, con bitácora de auditoría).
- Sustituir identificadores secuenciales por identificadores no adivinables (UUID) como capa adicional de defensa.

Hallazgo RT-04: Exposición de código fuente mediante archivo de respaldo residual

Clasificación	Security– Exposición de archivos de respaldo / código fuente
CWE	CWE-530: Exposure of Backup File to an Unauthorized Control Sphere
Referencia OWASP / estándar	OWASP A05:2021 – Security Misconfiguration
Componente / endpoint	transparencia.php.bak
Severidad	Alta
Dónde se encontró	http://localhost:8080/transparencia.php.bak

Comprobación y procedimiento de explotación

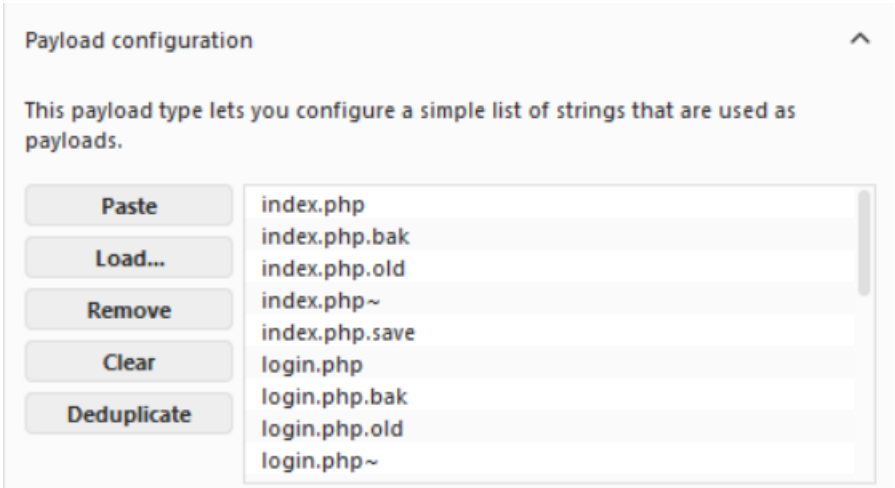
1. Se configuró Burp Suite Community como proxy del navegador y se navegó de forma normal por el portal, registrando en Target → Site map el listado completo de endpoints .php existentes.



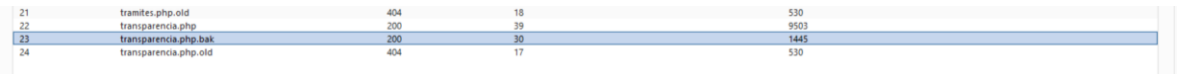
2. Con esa lista, se envió una petición base a Intruder (modo Sniper), marcando como posición variable el nombre del archivo solicitado en la URL.



3. Se cargó como payload cada nombre de archivo real combinado con extensiones típicas de copias de seguridad (.bak, .old, ~, .save), generando 24 variantes sobre los 6 endpoints principales.



4. Al comparar el código de estado y la longitud de cada respuesta, la mayoría de variantes devolvió 404; sin embargo, transparencia.php.bak devolvió 200 OK con un Content-Length muy inferior al de transparencia.php, indicando que no era la página renderizada sino un archivo distinto.



5. Al inspeccionar la respuesta completa, el servidor devolvió el código fuente PHP sin ejecutar, con cabecera Content-Type: application/x-trash, ya que Apache no reconoce .bak como extensión interpretable.



Causa raíz

El equipo de desarrollo dejó una copia de respaldo (transparencia.php.bak) dentro del document root público antes de una reorganización del módulo de transparencia, y nunca fue retirada tras la validación, contradiciendo el propio TODO documentado dentro del archivo. El servidor no restringe el acceso a extensiones no estándar dentro del directorio público.

Impacto y riesgo

- Exposición completa del código fuente del backend, incluyendo nombres internos de release, nombre del módulo y la estructura interna de secciones manejadas por el sistema.
- Revelación de comentarios internos de desarrollo y QA que documentan procesos de despliegue y pendientes de limpieza no ejecutados.

- Riesgo de reconocimiento previo a otros ataques: el código expuesto puede revelar funciones, parámetros o lógica de negocio que faciliten la explotación de otras vulnerabilidades.

Evidencia / bandera obtenida



Mitigación recomendada

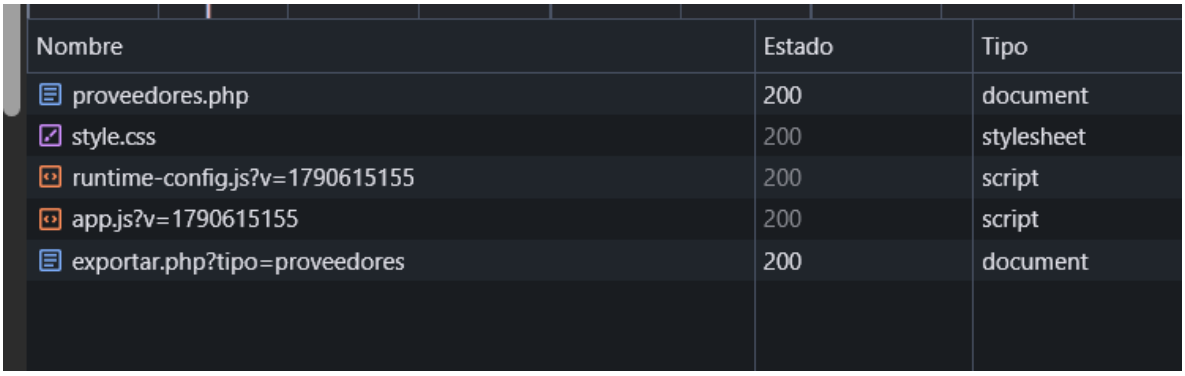
- Eliminar de forma inmediata todo archivo de respaldo, temporal o de prueba (.bak, .old, ~, .save, .swp) del document root público.
- Configurar Apache para denegar explícitamente el acceso a extensiones no reconocidas dentro del directorio público (bloque FilesMatch con Require all denied).
- Incorporar una verificación automática en el pipeline de CI/CD que escanee el document root antes de cada despliegue en busca de archivos residuales.

Hallazgo RT-05: Divulgación de información mediante manejo inadecuado de excepciones en exportar.php

Clasificación	Improper Error Handling / Information Disclosure
CWE	CWE-209: Generation of Error Message Containing Sensitive Information; CWE-248: Uncaught Exception
Referencia OWASP / estándar	OWASP A05:2021 – Security Misconfiguration
Componente / endpoint	exportar.php
Severidad	Media
Dónde se encontró	http://localhost:8080/exportar.php?tipo=

Comprobación y procedimiento de explotación

1. Se identificó la función de exportación de Excel en el módulo de proveedores, la cual, al hacer clic en "Descargar Excel", dispara la petición GET /exportar.php?tipo=proveedores.



2. Se probó un valor no contemplado por la interfaz original, enviando el parámetro tipo vacío directamente desde la barra de direcciones del navegador.



3. El servidor respondió con una página de diagnóstico interno completa en lugar de manejar el error de forma controlada, revelando información sensible del backend directamente en el navegador.

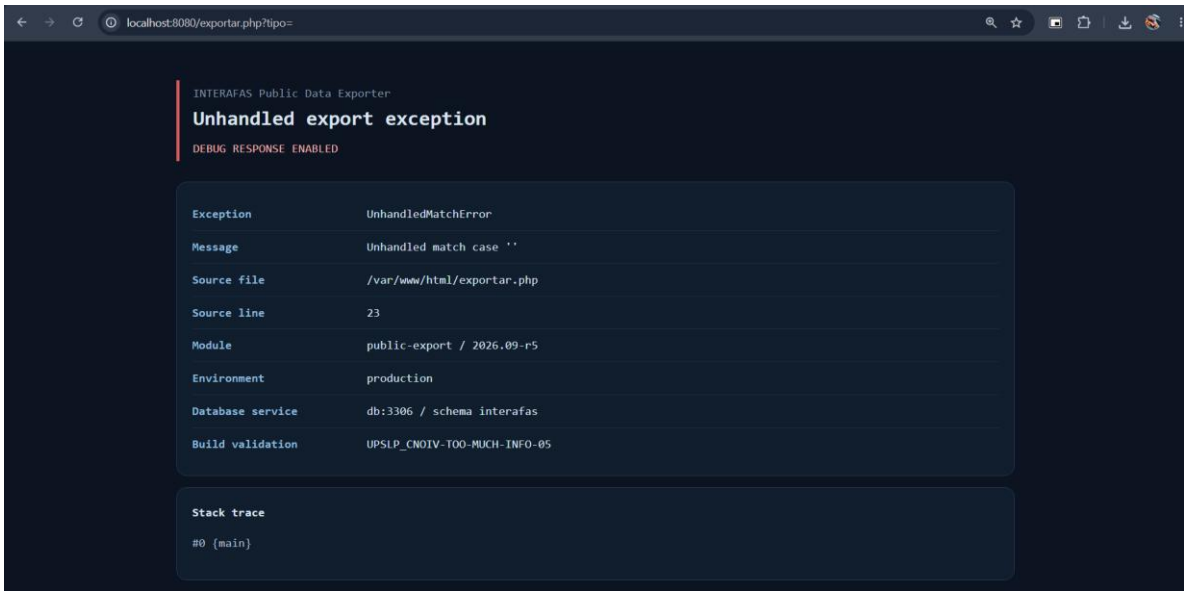
Causa raíz

El endpoint usa una expresión match de PHP para decidir el tipo de exportación según el parámetro tipo, sin incluir una rama default que capture valores no previstos, por lo que PHP lanza un UnhandledMatchError no controlado. A esto se suma que el entorno tiene el modo de depuración activo en producción, provocando que la excepción se imprima íntegra al usuario final.

Impacto y riesgo

- Explotación trivial: basta con editar la URL en el navegador, sin herramientas especializadas, reduciendo drásticamente la barrera técnica.
- Revelación de la estructura de archivos del servidor y la línea exacta del código con el error.
- Exposición de detalles de infraestructura de base de datos (host, puerto, nombre de esquema), información valiosa para intentos posteriores de inyección SQL o movimiento lateral.
- Confirmación explícita de que se trata del entorno de producción.

Evidencia / bandera obtenida



Mitigación recomendada

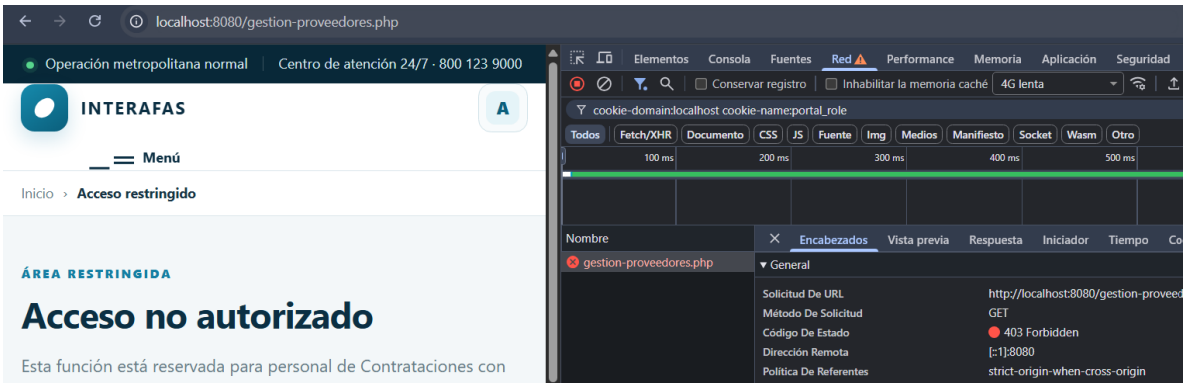
- Desactivar el modo de depuración en todo entorno de producción; los errores deben registrarse únicamente en logs internos protegidos.
- Agregar una rama default en la expresión match de exportar.php que devuelva una respuesta genérica y controlada (HTTP 400), sin exponer detalles internos.
- Implementar un manejador global de excepciones (set_exception_handler) que capture cualquier error no previsto en toda la aplicación.

Hallazgo RT-06: Escalamiento de privilegios verticales mediante cookie de rol controlada por el cliente

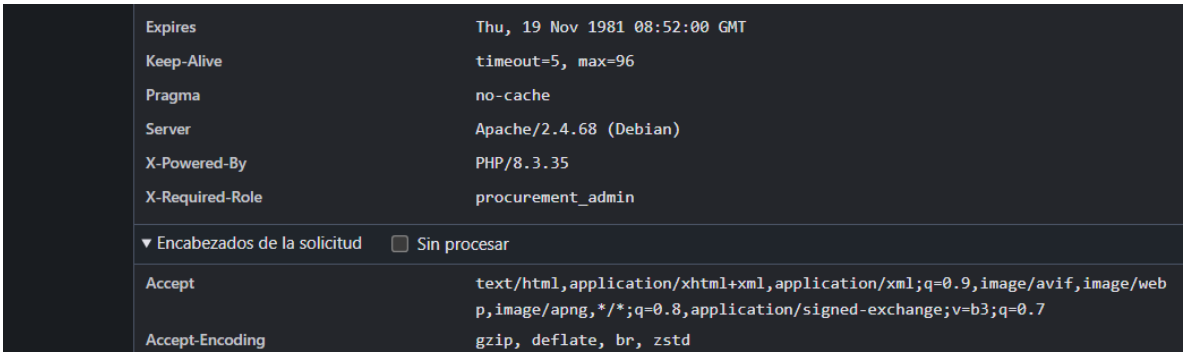
Clasificación	Broken Access Control – Privilege Escalation / Improper Authorization based on Client-Controlled Data
CWE	CWE-266: Incorrect Privilege Assignment; CWE-639: Authorization Bypass Through User-Controlled Key
Referencia OWASP / estándar	OWASP A01:2021 – Broken Access Control
Componente / endpoint	gestion-proveedores.php
Severidad	Crítica
Dónde se encontró	http://localhost:8080/gestion-proveedores.php

Comprobación y procedimiento de explotación

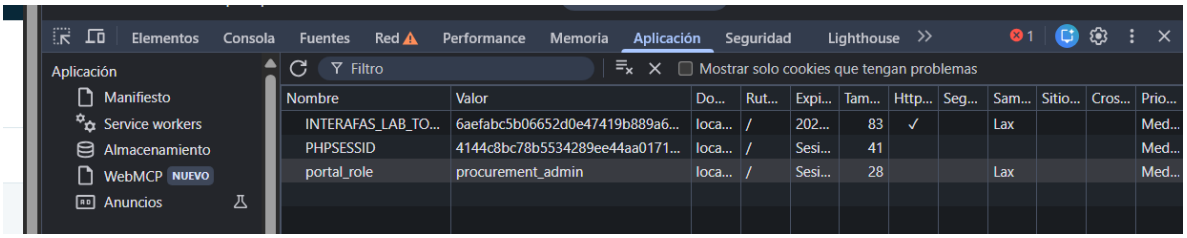
1. Se inició sesión con una cuenta ciudadana estándar y, mediante las Herramientas de desarrollador (F12 → Application → Cookies), se confirmó que la sesión establece una cookie portal_role=citizen tras el login.
2. Navegando el padrón público de proveedores se identificó un enlace hacia gestion-proveedores.php, un módulo no destinado a ciudadanos.



3. Al acceder con la sesión ciudadana, el servidor respondió 403 Forbidden, pero en la pestaña Network se identificó una cabecera no destinada a mostrarse en pantalla: X-Required-Role: procurement_admin.



4. Se modificó manualmente el valor de la cookie portal_role de citizen a procurement_admin, sin alterar ninguna otra credencial.



5. Se recargó la página: el servidor respondió 200 OK, otorgando acceso completo al módulo de gestión del padrón de proveedores.



6. Se ejecutó la acción administrativa "Restaurar vigente" sobre el registro de un proveedor, confirmando capacidad de escritura con la sesión ciudadana modificada.

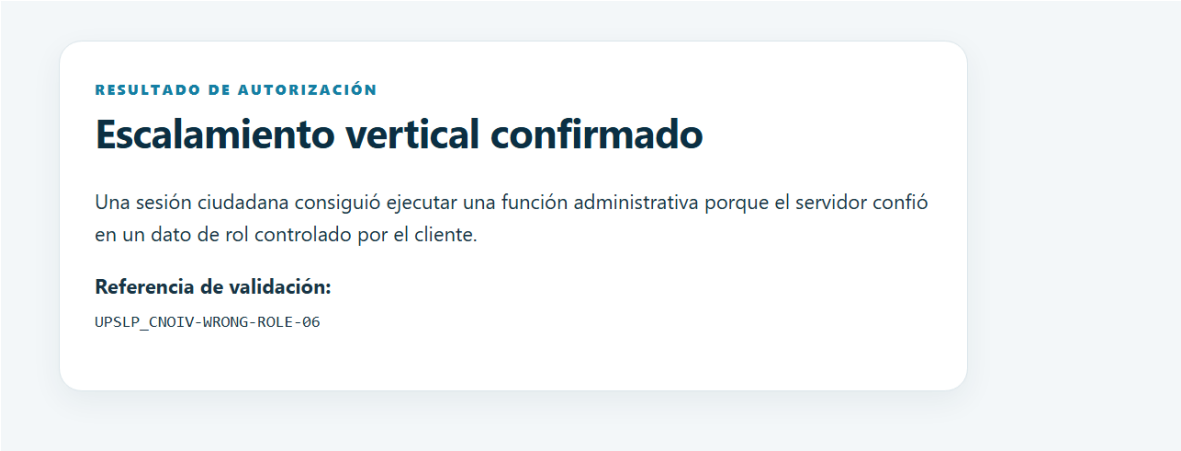
Causa raíz

El servidor determina el nivel de autorización exclusivamente a partir de una cookie (portal_role) que viaja sin protección criptográfica ni validación contra una fuente de verdad en el backend. La aplicación verifica la presencia de un rol autorizado, pero no que ese rol corresponda realmente al usuario autenticado. Agravando el problema, la propia respuesta de error (X-Required-Role) revela el valor exacto necesario para evadir el control.

Impacto y riesgo

- Explotación trivial, sin herramientas especializadas: todo el hallazgo se realizó únicamente con las Herramientas de desarrollador nativas del navegador.
- Escalamiento de privilegios verticales completo: cualquier ciudadano autenticado puede ejecutar funciones administrativas reservadas a personal de Contrataciones.
- Autoexplotación guiada por el propio servidor mediante la cabecera X-Required-Role.
- Patrón sistémico: otras funciones internas podrían ser vulnerables al mismo bypass con distintos valores de rol.

Evidencia / bandera obtenida



Mitigación recomendada

- Eliminar la dependencia de un valor de rol controlado por el cliente; la autorización debe determinarse en el backend contra el rol real del usuario autenticado.
- Si se requiere persistir el rol en el cliente, firmarlo criptográficamente (JWT firmado) para que cualquier modificación invalide la firma.
- Eliminar la cabecera X-Required-Role de las respuestas destinadas al cliente.

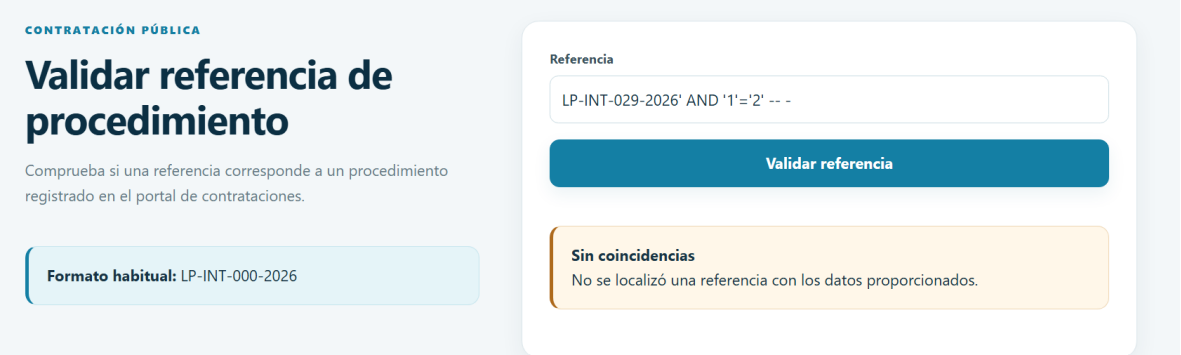
Hallazgo RT-07: Inyección SQL ciega basada en booleanos en validador de referencias de licitación

Clasificación	Injection – SQL Injection (Boolean-Based Blind)
CWE	CWE-89: Improper Neutralization of Special Elements used in an SQL Command
Referencia OWASP / estándar	OWASP A03:2021 – Injection
Componente / endpoint	validar-referencia.php
Severidad	Crítica
Dónde se encontró	http://localhost:8080/validar-referencia.php?ref=

Comprobación y procedimiento de explotación

1. Se identificó el formulario público "Validar referencia de procedimiento", que responde con uno de dos mensajes fijos ("Referencia localizada" o "Sin coincidencias") sin mostrar datos adicionales.

2. Se confirmó manualmente el canal booleano manipulando el parámetro ref con condiciones SQL: x' OR '1'='1 forzó "Referencia localizada" y x' AND '1'='2 forzó "Sin coincidencias", demostrando que la entrada se concatena sin sanitización en la consulta SQL.



3. Dado que explotar manualmente una inyección ciega carácter por carácter es extremadamente lento, se utilizó sqlmap para automatizar la extracción, reutilizando el mismo canal booleano ya confirmado.

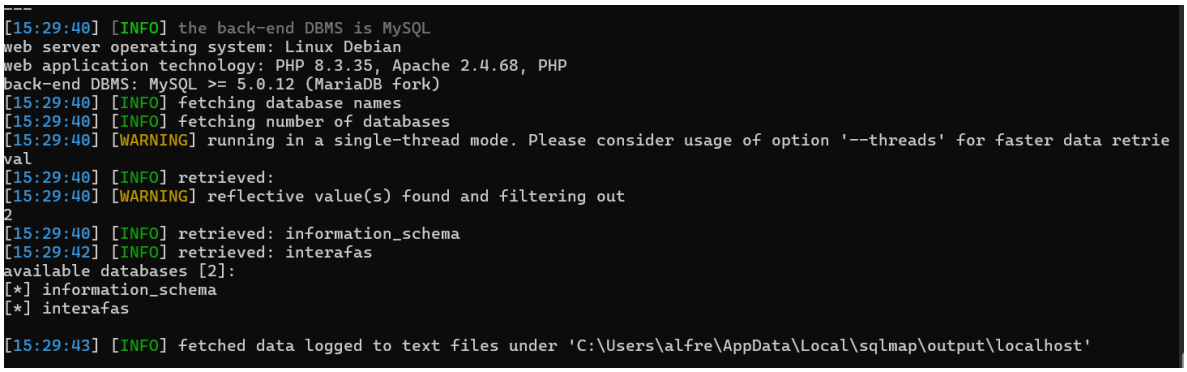
4. sqlmap confirmó tres técnicas explotables sobre el mismo parámetro: boolean-based blind, stacked queries y time-based blind, identificando MySQL/MariaDB sobre Apache 2.4.68 y PHP 8.3.35.

```
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: ref (GET)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: ref=LP-INT-029-2026' AND 7882=7882 AND 'dMWD'='dMWD

    Type: stacked queries
    Title: MySQL >= 5.0.12 stacked queries (comment)
    Payload: ref=LP-INT-029-2026';SELECT SLEEP(5)#

    Type: time-based blind
    Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
    Payload: ref=LP-INT-029-2026' AND (SELECT 9830 FROM (SELECT(!SLEEP(5)))yZby) AND 'scsQ'='scsQ
---
```

5. Mediante enumeración de information_schema se listó la base de datos interafas y sus 32 tablas, identificando portal_validation_meta como tabla de interés.





6. Se extrajo selectivamente, mediante el canal booleano automatizado por sqlmap, el campo de validación correspondiente, confirmando el token verification_token = UPSLP_CNOIV-SILENT-ANSWER-07.

Causa raíz

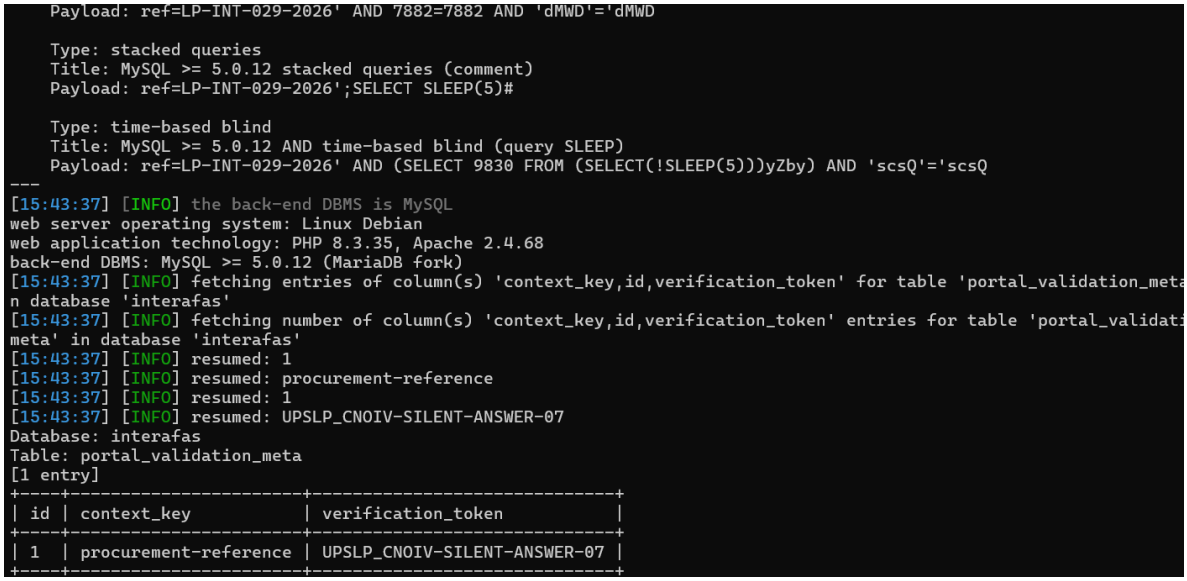
El parámetro ref recibido por $_GET se concatena directamente dentro de una sentencia SQL sin el uso de consultas preparadas ni ningún mecanismo de escape. Adicionalmente, cualquier error de sintaxis SQL se captura internamente y se oculta al usuario, mostrando el mismo mensaje genérico de "sin resultados", lo que refuerza la explotabilidad al garantizar un canal de inferencia binario estable.

Impacto y riesgo

- Acceso no autorizado a toda la base de datos sin autenticación: el endpoint es de acceso público, por lo que cualquier visitante puede enumerar y extraer el contenido completo de la base de datos interafas.
- Extracción completa automatizable mediante herramientas estándar de la industria (sqlmap), sin ver un solo resultado en pantalla ni mensaje de error SQL.

- Dado que la inyección también es explotable vía stacked queries, un atacante podría potencialmente modificar o insertar registros si los permisos del usuario de base de datos lo permiten.
- Patrón de riesgo sistémico: otros puntos del portal que interactúan con la base de datos podrían compartir la misma práctica insegura de construcción de consultas.

Evidencia / bandera obtenida



Mitigación recomendada

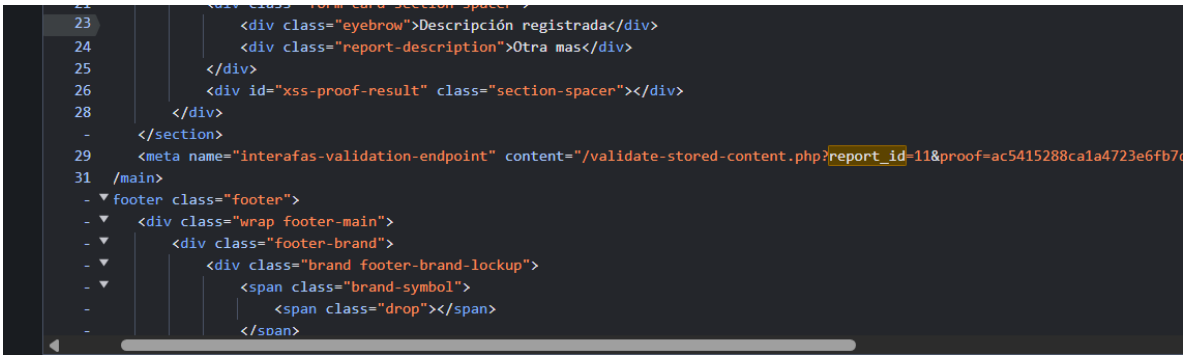
- Sustituir la concatenación de cadenas por consultas preparadas (prepared statements) con parámetros vinculados en todos los puntos de acceso a la base de datos.
- Aplicar validación estricta de formato de entrada (p. ej. expresión regular para el patrón LP-INT-000-2026) antes de procesar la referencia.
- No ocultar errores de sintaxis SQL de forma indiscriminada; registrar los intentos fallidos para detección de ataques.
- Aplicar el principio de mínimo privilegio al usuario de base de datos utilizado por la aplicación web.

Hallazgo RT-08: Cross-Site Scripting Almacenado (Stored XSS) en campo de descripción de reportes ciudadanos

Clasificación	Injection – Stored Cross-Site Scripting
CWE	CWE-79: Improper Neutralization of Input During Web Page Generation; CWE-80
Referencia OWASP / estándar	OWASP A03:2021 – Injection
Componente / endpoint	reportes.php (inyección) / seguimiento-reporte.php?id=X (ejecución)
Severidad	Alta
Dónde se encontró	http://localhost:8080/reportes.php (punto de inyección); http://localhost:8080/seguimiento-reporte.php?id=X (punto de ejecución)

Comprobación y procedimiento de explotación

1. Se identificó el formulario público de reportes.php, utilizado por cualquier ciudadano para levantar reportes de incidencias. El campo Descripción se envía al servidor y queda asociado permanentemente a un registro en base de datos.
2. Tras enviar un reporte de prueba, se confirmó en seguimiento-reporte.php que el valor se reflejaba sin ninguna codificación HTML dentro de un div.report-description.
3. Inspeccionando el HTML de la vista de seguimiento se localizó un mecanismo de acreditación: un meta interafas-validation-endpoint con un report_id y un token proof, apuntando a /validate-stored-content.php.



4. Se construyó un payload que, al ejecutarse en el contexto de la página, leyera ese meta en tiempo real y realizara una petición HTTP (fetch) hacia el endpoint de validación.




```
            <dd>2026-10-05 05:21:45</dd>
        </div>
    </div>
    <div class="form-card section-spacer">
        <div class="eyebrow">Descripción registrada</div>
        <div class="report-description">
            <script>
                window.addEventListener('load', function() {
                    const meta = document.querySelector('meta[name="interafas-validation-endpoint"]');
                    const resultDiv = document.getElementById('xss-proof-result');
                    if (!meta || !resultDiv)
                        return;
                    fetch(meta.content).then(r => r.text()).then(t => {
                        resultDiv.innerText = 'PROOF: ' + t;
                    }
                    ).catch(e => {
                        resultDiv.innerText = 'ERROR: ' + e;
                    }
                    );
                });
            </script>
        </div>
    </div>
    <div id="xss-proof-result" class="section-spacer"></div>
```

5. Al visitar el reporte resultante, el div#xss-proof-result mostró el texto PROOF: UPSLP_CNOIV-STORED-WORDS-08, confirmando que el script almacenado ejecutó una petición HTTP legítima en el contexto del navegador de la víctima.

Causa raíz

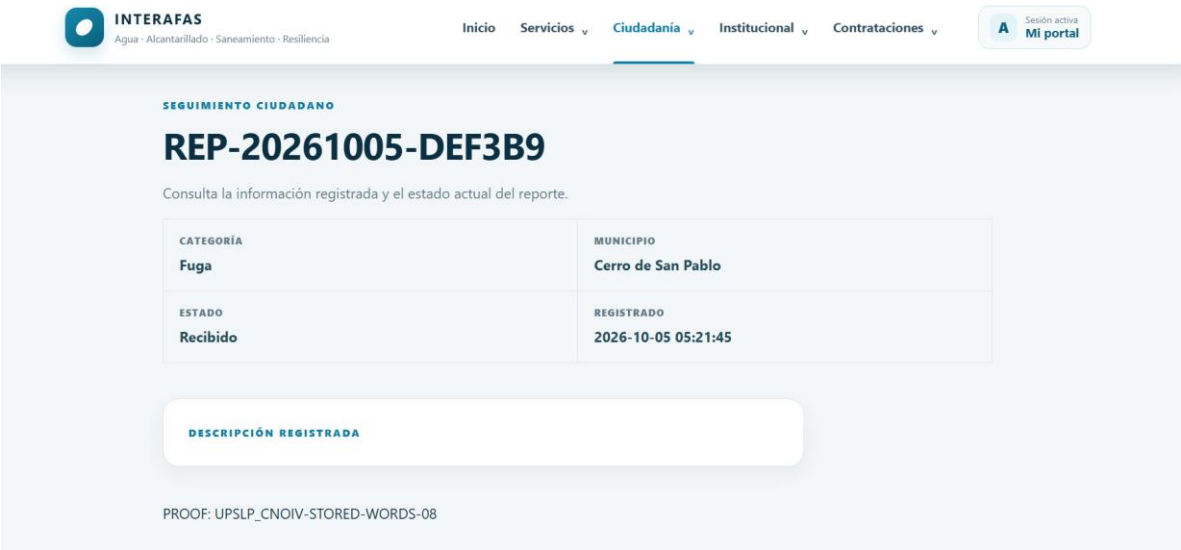
La aplicación almacena el contenido del campo Descripción sin sanitización ni validación de entrada, y lo renderiza posteriormente sin aplicar codificación de salida (output encoding) al contexto HTML. Esto permite que cualquier contenido HTML/JavaScript ingresado por un usuario, incluso anónimo, se interprete como código ejecutable por el navegador de cualquier otra persona que visite esa página.

Impacto y riesgo

- Ejecución persistente y de amplio alcance: el payload queda almacenado en base de datos y se ejecuta automáticamente contra cualquier usuario que visite el reporte afectado, incluyendo personal interno.
- Explotación trivial, sin herramientas especializadas: basta escribir código en un campo de formulario público.

- Capacidad demostrada de ejecutar peticiones HTTP arbitrarias en el contexto de la víctima (mismo origen, potencialmente mismas cookies/sesión), lo que en un escenario real permitiría exfiltrar tokens de sesión.

Evidencia / bandera obtenida



Mitigación recomendada

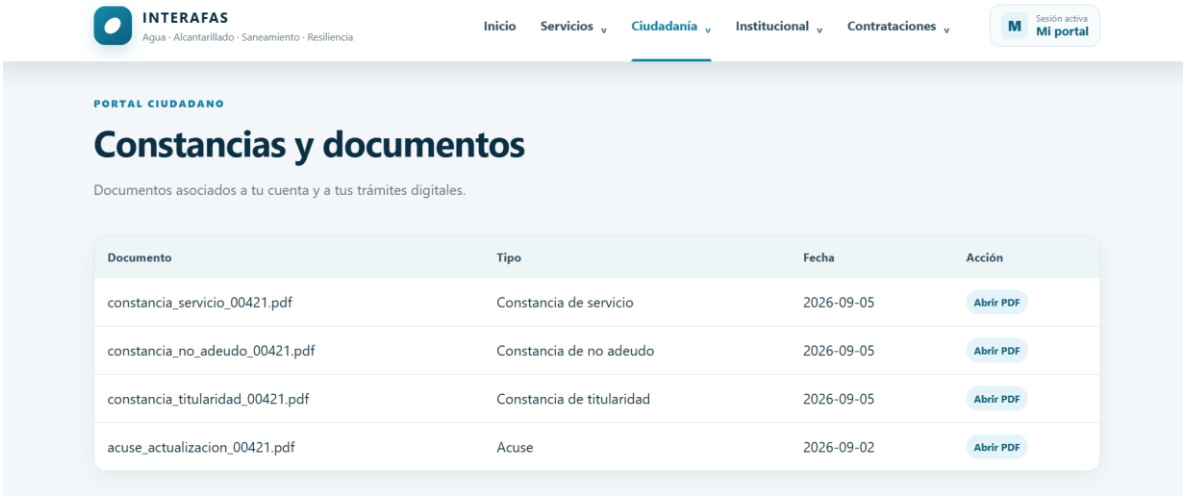
- Aplicar codificación de salida (output encoding) contextual a HTML en todo contenido generado por el usuario antes de renderizarlo.
- Sanitizar la entrada en el campo Descripción eliminando o neutralizando etiquetas HTML/JavaScript no permitidas (lista blanca de formato, si aplica).
- Implementar una Content-Security-Policy estricta que impida la ejecución de scripts inline y restrinja los destinos de fetch/XHR.
- Auditar otros campos de texto libre del portal (comentarios, nombre del solicitante, campos de contacto) bajo el mismo criterio.

Hallazgo RT-09: Path Traversal en función de descarga de documentos ciudadanos

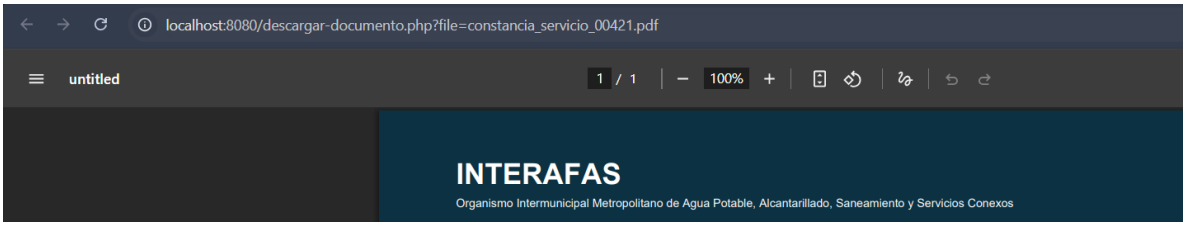
Clasificación	Path Traversal / Local File Inclusion
CWE	CWE-22: Improper Limitation of a Pathname to a Restricted Directory
Referencia OWASP / estándar	OWASP A01:2021 – Broken Access Control
Componente / endpoint	descargar-documento.php
Severidad	Crítica
Dónde se encontró	http://localhost:8080/descargar-documento.php?file=

Comprobación y procedimiento de explotación

1. Se identificó un botón de descarga de documentos ("Abrir PDF") en "Mis documentos" del portal ciudadano. La URL seguía el patrón descargar-documento.php?file=NOMBRE.pdf.

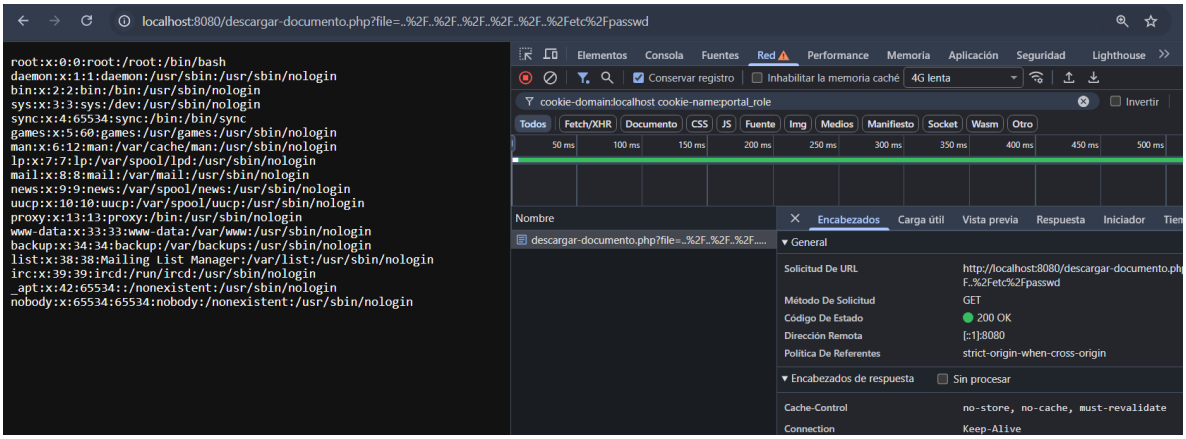


2. Se confirmó el comportamiento legítimo solicitando nombres de archivo reales conocidos, servidos correctamente por el servidor.



3. Se intentó navegar fuera del directorio usando secuencias ../ de forma literal, sin resultado, ya que el navegador normalizaba automáticamente dichas secuencias.

4. Al codificar la secuencia como %2F (equivalente URL-encoded de /), forzando que viajara intacta hasta el servidor, se confirmó la vulnerabilidad: una petición con seis niveles de ../ permitió acceder a /etc/passwd.



5. Siguiendo la metodología de contrastar con archivos estándar del sistema operativo, se repitió la prueba contra /etc/motd, obteniendo como respuesta el token de validación del laboratorio.

Causa raíz

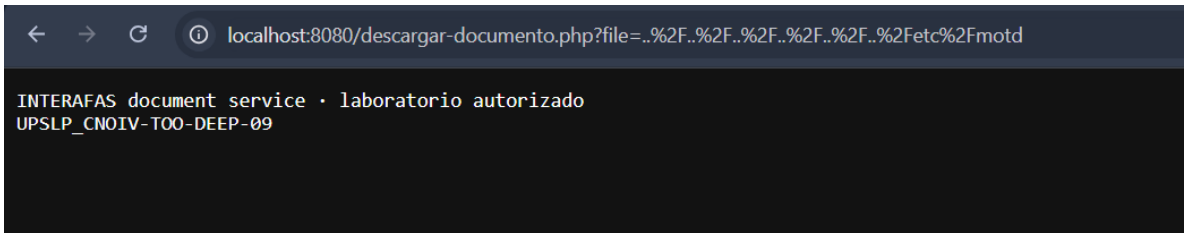
El nombre de archivo recibido mediante el parámetro file se concatena directamente al directorio base esperado ($baseDir.'/'.$file) sin normalización de ruta ni verificación de que el archivo resultante permanezca dentro del directorio autorizado. La función readfile() se invoca sobre esa ruta concatenada sin restricción alguna.

Impacto y riesgo

- Lectura arbitraria de archivos del sistema operativo fuera de cualquier directorio relacionado con la aplicación.
- Explotación sin autenticación robusta ni herramientas especializadas: solo manipulación de la URL desde el navegador.

- Superficie de exposición amplia: cualquier archivo legible por el usuario del proceso PHP (www-data) es potencialmente exfiltrable, incluyendo código fuente y archivos de configuración con credenciales de base de datos.

Evidencia / bandera obtenida



Mitigación recomendada

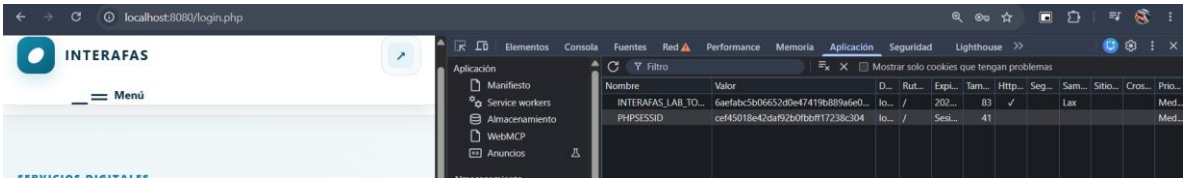
- Normalizar y validar la ruta resultante en el servidor (realpath) verificando que permanezca dentro del directorio base autorizado antes de servir el archivo.
- Utilizar un mapa de identificadores controlados por el servidor (whitelist) en lugar de aceptar nombres de archivo/ruta directamente del cliente.

Hallazgo RT-10: Fijación de Sesión (Session Fixation) por ausencia de regeneración de identificador al autenticar

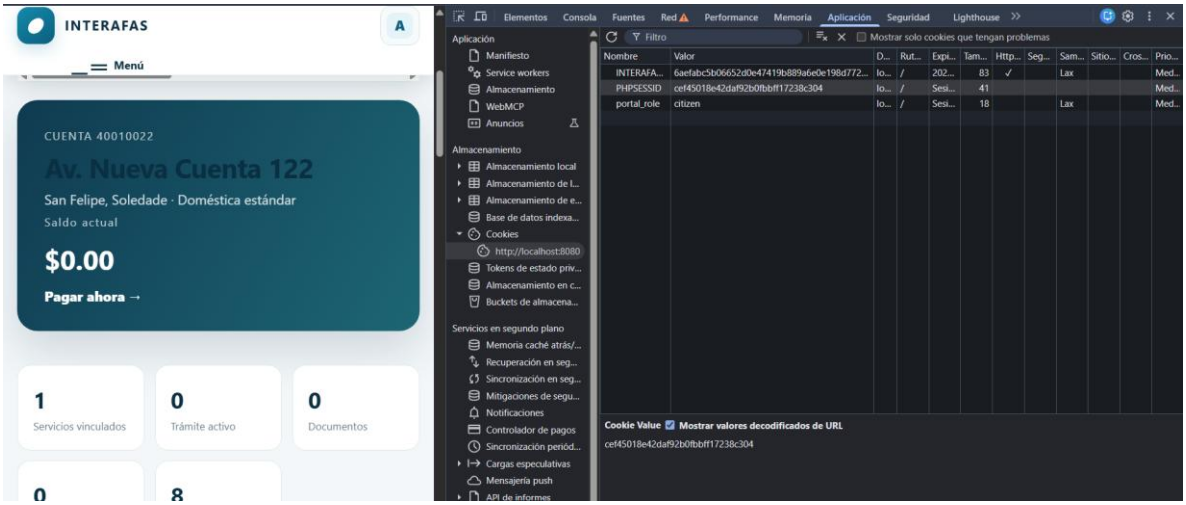
Clasificación	Session Management – Session Fixation
CWE	CWE-384: Session Fixation
Referencia OWASP / estándar	OWASP A07:2021 – Identification and Authentication Failures
Componente / endpoint	login.php / perfil.php
Severidad	Alta
Dónde se encontró	http://localhost:8080/login.php (punto de la falla); http://localhost:8080/perfil.php (punto de confirmación)

Comprobación y procedimiento de explotación

1. Se accedió al portal sin sesión iniciada y se registró el identificador de sesión asignado por el servidor antes de cualquier autenticación (PHPSESSID).



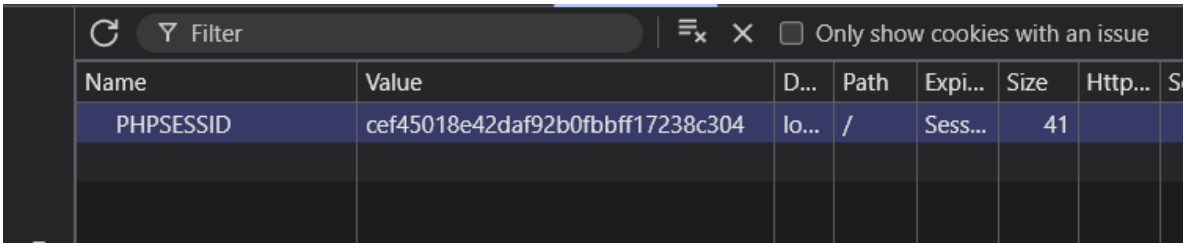
2. Se inició sesión con una cuenta ciudadana estándar y se verificó nuevamente el valor de PHPSESSID tras el login: resultó ser exactamente el mismo que el registrado antes de autenticarse.



3. Para demostrar el impacto real, se simuló un segundo cliente independiente usando un navegador distinto, con su propio almacenamiento de cookies.



4. En ese segundo navegador se editó manualmente, vía DevTools, el valor de la cookie PHPSESSID para que coincidiera con el identificador capturado en el paso 1, sin introducir ninguna credencial; la sesión quedó reconocida como autenticada al navegar a /panel.php.



5. Se visitó /perfil.php desde ese segundo cliente, lo que activó cabeceras de acreditación (X-INTERAFAS-Session-State: replay-accepted) confirmando la reutilización exitosa de la sesión desde un cliente distinto.

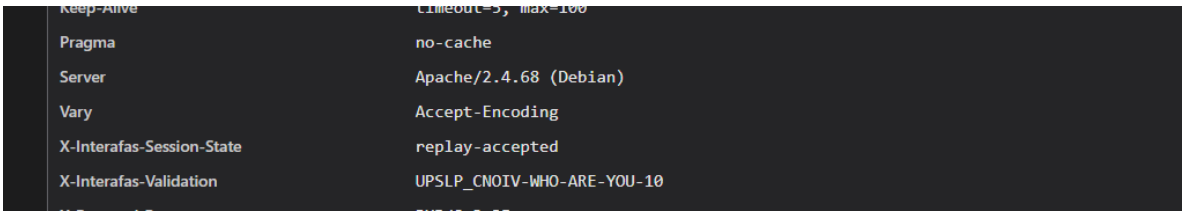
Causa raíz

La aplicación crea una sesión PHP desde el primer acceso anónimo y, al autenticar al usuario, no invoca session_regenerate_id(true) para emitir un nuevo identificador asociado al estado autenticado. El identificador observado o fijado previamente por un atacante conserva su validez después de que la víctima inicia sesión.

Impacto y riesgo

- Secuestro de sesión sin necesidad de robar credenciales ni interceptar tráfico, bastando con conocer o fijar de antemano un identificador de sesión válido.
- Explotación verificada desde un cliente completamente independiente (navegador distinto, almacenamiento de cookies separado).
- Superficie de ataque amplia y de bajo costo técnico: solo requiere editar manualmente una cookie desde las herramientas nativas del navegador.

Evidencia / bandera obtenida



Mitigación recomendada

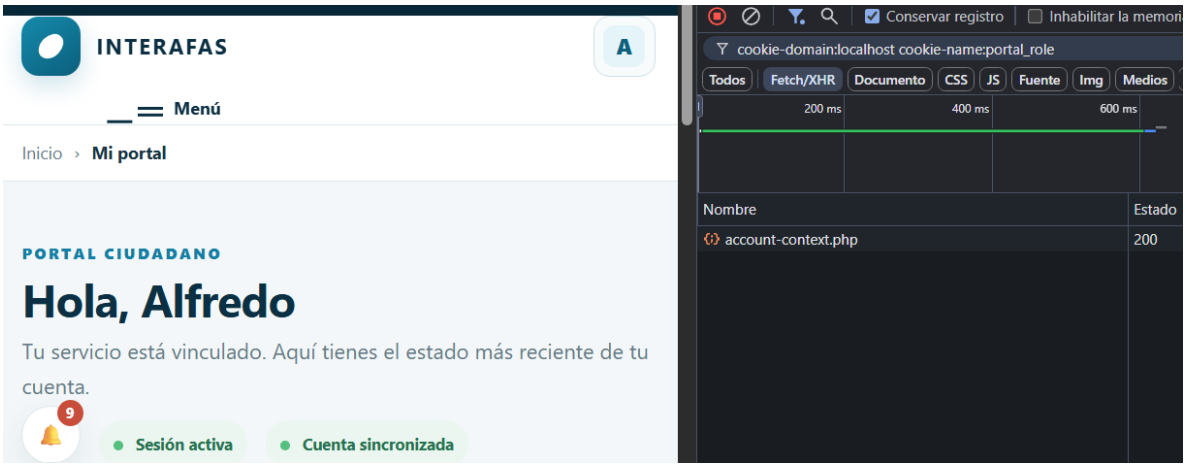
- Invocar session_regenerate_id(true) inmediatamente después de una autenticación exitosa, invalidando el identificador de sesión previo al login.
- Vincular la sesión a atributos adicionales del cliente (p. ej. User-Agent) como capa de defensa adicional, sin usarlos como único control.
- Establecer tiempos de expiración cortos para sesiones no autenticadas.

Hallazgo RT-11: Gestión Inadecuada de Inventario de API – Endpoint No Documentado de Historial de Servicio

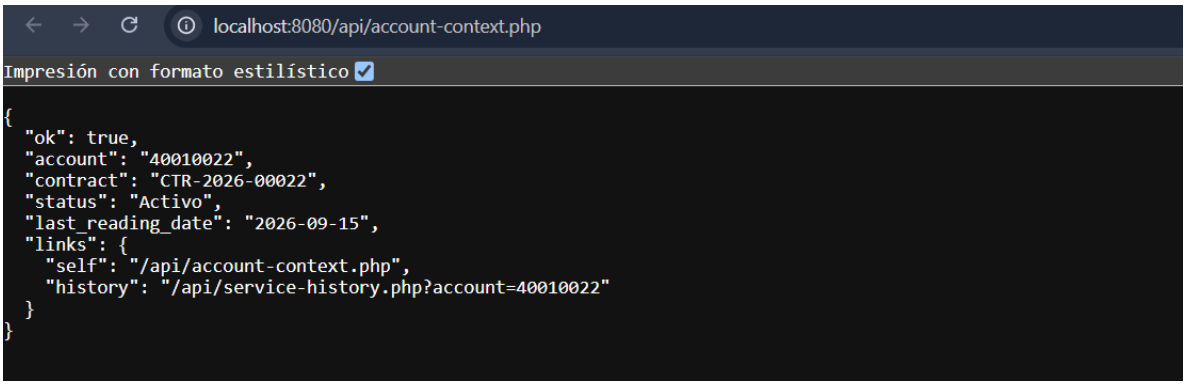
Clasificación	API Security – Improper Inventory Management
CWE	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
Referencia OWASP / estándar	OWASP API9:2023 – Improper Inventory Management
Componente / endpoint	/api/account-context.php, /api/service-history.php
Severidad	Media
Dónde se encontró	http://localhost:8080/api/account-context.php (descubrimiento); http://localhost:8080/api/service-history.php?account=40010022 (recurso no documentado)

Comprobación y procedimiento de explotación

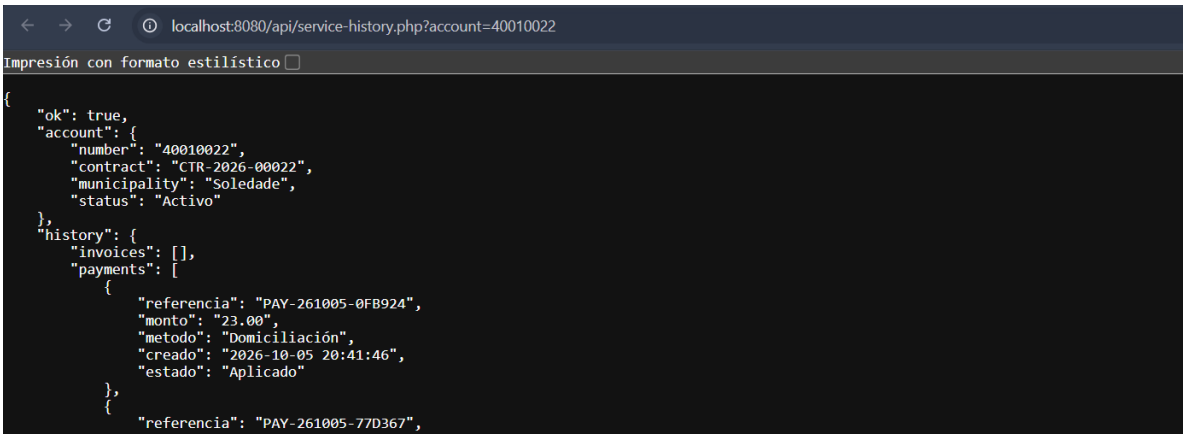
1. Se navegó por "Mi Portal" con las Herramientas de desarrollador abiertas (pestaña Network, filtro XHR/Fetch), observando solicitudes en segundo plano sin limitarse al contenido visible en el HTML.



2. Se identificó la llamada account-context.php y, al inspeccionar el cuerpo completo de la respuesta JSON, se encontró un objeto links no utilizado por la interfaz.



3. Se solicitó directamente el recurso referenciado (service-history.php?account=40010022), reutilizando la sesión autenticada existente, sin credenciales adicionales.



4. El servidor respondió con 200 OK y un cuerpo JSON válido, confirmando que el endpoint está activo pese a que ninguna vista del portal lo invoca ni enlaza a él.
5. La respuesta incluyó las cabeceras X-Interafas-Endpoint-Status: undocumented y X-Interafas-Validation: UPSLP_CNOIV-HIDDEN-HISTORY-11.

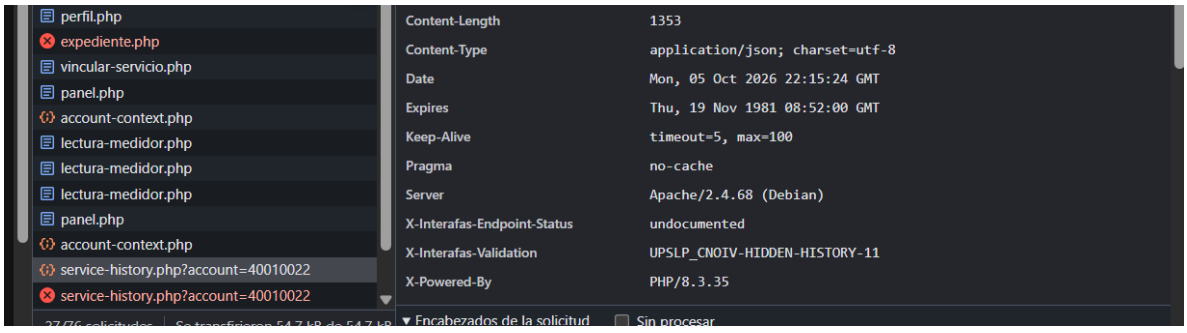
Causa raíz

El backend conserva en producción un endpoint de historial de servicio que en algún momento formó parte de una función del portal, planeada o descontinuada, y que nunca fue removido ni desactivado al dejar de utilizarse desde la interfaz. La aplicación no mantiene un inventario formal de sus endpoints activos.

Impacto y riesgo

- Exposición de datos fuera del flujo de uso previsto: el historial de servicio puede consultarse sin pasar por ningún control de la interfaz oficial.
- Ampliación de la superficie de ataque real frente a la percibida: la superficie efectiva incluye endpoints "huérfanos" descubribles mediante inspección de tráfico.
- Riesgo de IDOR asociado, al aceptar account como parámetro directo (confirmado posteriormente en el Hallazgo 12).

Evidencia / bandera obtenida



Mitigación recomendada

- Mantener un inventario formal y versionado de todos los endpoints activos del backend, con revisión periódica.

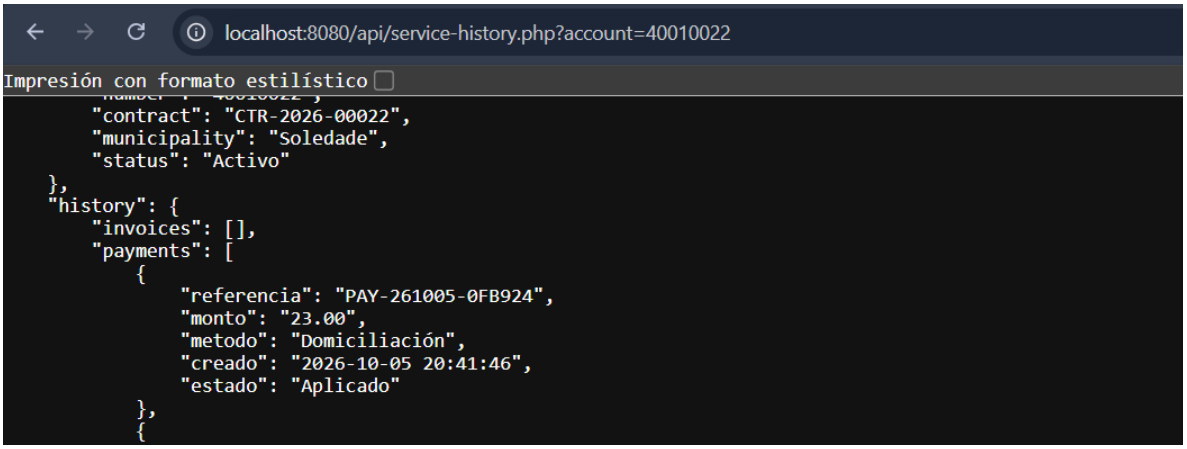
- Establecer un proceso de retiro (deprecation) que desactive endpoints no referenciados por ninguna interfaz vigente.
- Aplicar autenticación y autorización explícitas a cualquier endpoint de API, independientemente de si es consumido por el frontend actual.

Hallazgo RT-12: Autorización Rota a Nivel de Objeto (BOLA) – Acceso Cruzado entre Cuentas vía Parámetro account

Clasificación	API Security – Broken Object Level Authorization
CWE	CWE-639: Authorization Bypass Through User-Controlled Key
Referencia OWASP / estándar	OWASP API1:2023 – Broken Object Level Authorization
Componente / endpoint	/api/service-history.php?account=
Severidad	Crítica
Dónde se encontró	http://localhost:8080/api/service-history.php?account=40010022 (endpoint del Hallazgo 11) y con identificador de otra cuenta

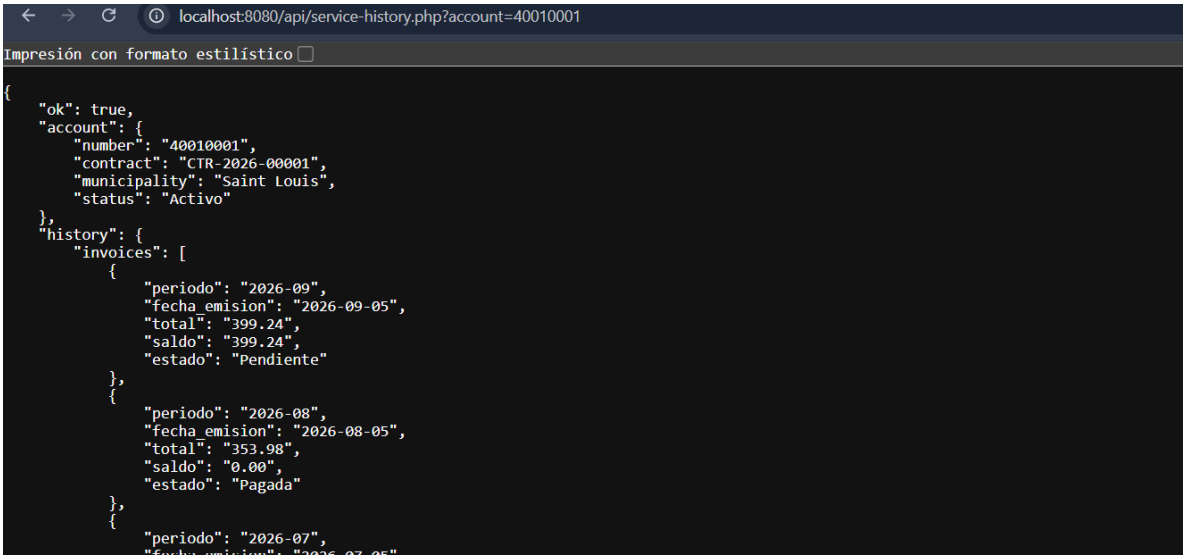
Comprobación y procedimiento de explotación

1. A partir del endpoint no documentado del Hallazgo 11, se identificó que la cuenta a consultar se selecciona enteramente mediante el parámetro account, sin ningún otro valor que amarre la petición a una cuenta específica.



2. Se mantuvo la misma sesión autenticada usada para las demás llamadas del portal, sin alterar ningún mecanismo de autenticación.

3. Se repitió la petición cambiando únicamente el valor de account por el identificador de otra cuenta válida del laboratorio, distinta de la propia.



4. El servidor respondió con 200 OK, devolviendo el historial de servicio de la cuenta ajena con los mismos campos estructurales que la respuesta legítima.

5. La respuesta incluyó la cabecera X-Interafas-Validation: UPSLP_CNOIV-SECOND-ACCOUNT-12.

Causa raíz

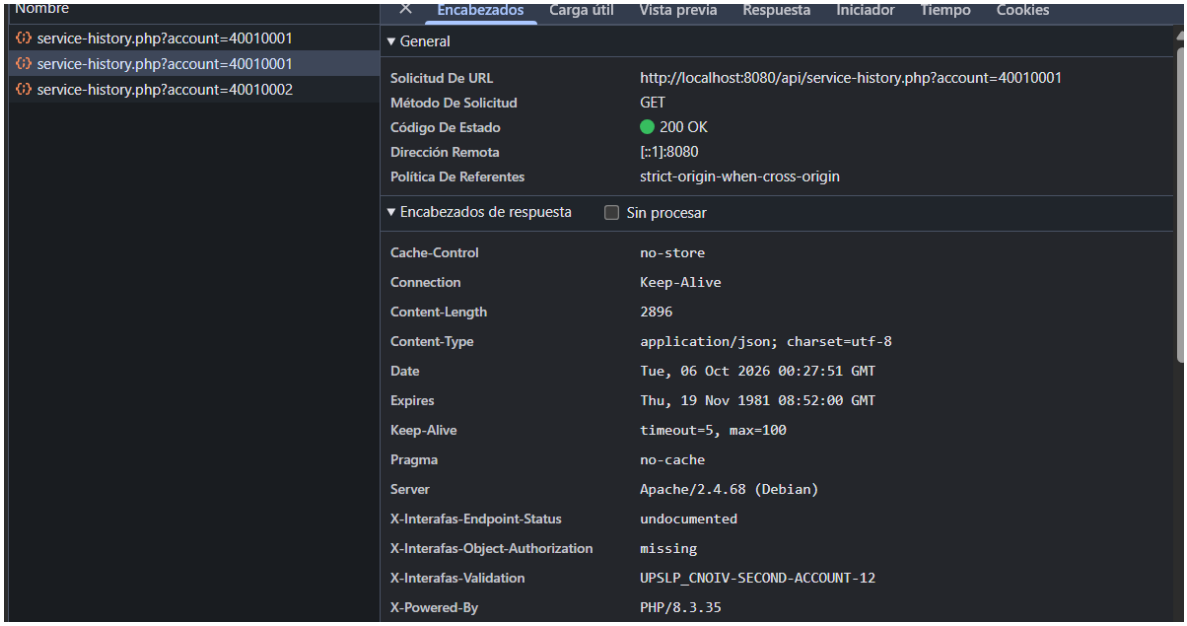
El endpoint service-history.php autentica al usuario, pero no autoriza el objeto solicitado: nunca compara el valor de account recibido contra la cuenta real asociada a la sesión activa. La identidad del usuario y el objeto consultado se tratan como independientes.

Impacto y riesgo

- Acceso horizontal no autorizado: cualquier usuario autenticado puede consultar el historial de servicio de cualquier otra cuenta con solo conocer o adivinar su identificador.
- Confidencialidad comprometida a escala si los identificadores de cuenta son enumerables, permitiendo iterar sobre el rango completo.

- Efecto compuesto con el Hallazgo 11: la falta de inventario expuso la existencia del endpoint y esta falla de autorización lo vuelve explotable más allá de la propia cuenta.
- Violación del principio de autenticación ≠ autorización, el patrón de fallo más común detrás de IDOR/BOLA en APIs REST.

Evidencia / bandera obtenida



Mitigación recomendada

- Validar en el backend que el valor de account recibido coincide con la cuenta real asociada a la sesión autenticada antes de devolver cualquier dato.
- Derivar el objeto consultado de la sesión en lugar de aceptarlo directamente del cliente, cuando sea posible.

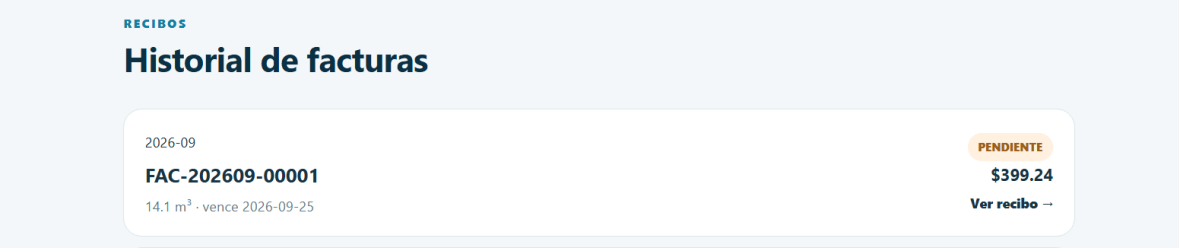
Hallazgo RT-13: Abuso de Lógica de Negocio en Flujo de Pago por Ausencia de Revalidación del Importe

Clasificación	Business Logic – Excessive Trust in Client-Side Controls
CWE	CWE-840: Business Logic Errors

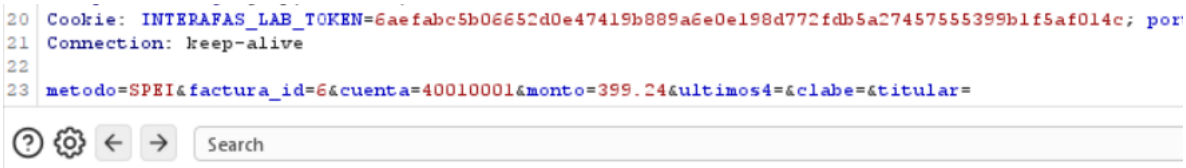
Referencia OWASP / estándar	OWASP WSTG-BUSLOGIC
Componente / endpoint	pago.php
Severidad	Alta
Dónde se encontró	http://localhost:8080/pago.php?factura=6 (punto de la falla); POST /pago.php (punto de explotación)

Comprobación y procedimiento de explotación

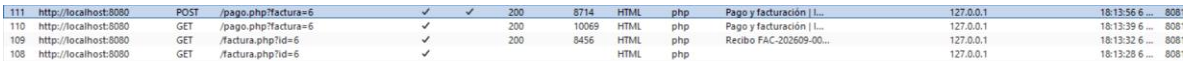
1. Se accedió al flujo de pago de un recibo pendiente (saldo $399.24). La interfaz comunicó que el importe se fija automáticamente y no admite parcialidades, mostrando el campo Importe bloqueado para edición.

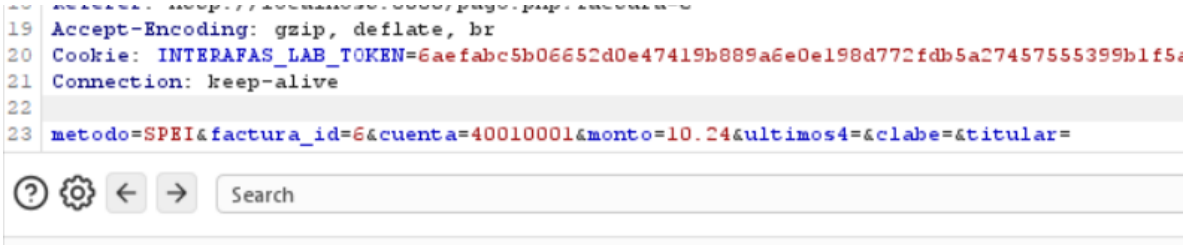


2. Se capturó la solicitud POST /pago.php disparada al confirmar el pago, identificando los campos enviados (metodo, factura_id, cuenta, monto, ultimos4, clabe, titular).



3. Usando Burp Suite en modo Intercept, se retuvo la solicitud y se editó manualmente el campo monto, reduciéndolo de 399.24 a 10.24, conservando sin cambios factura_id y cuenta.





4. Se reenvió la solicitud modificada. El servidor respondió 200 OK con el mensaje "Pago recibido" y generó una referencia de operación válida, sin rechazar ni ajustar el monto recibido.
5. La respuesta incluyó las cabeceras X-INTERAFAS-Business-Rule: amount-not-revalidated y X-INTERAFAS-Validation: UPSLP_CNOIV-PAYMENT-PATH-13.

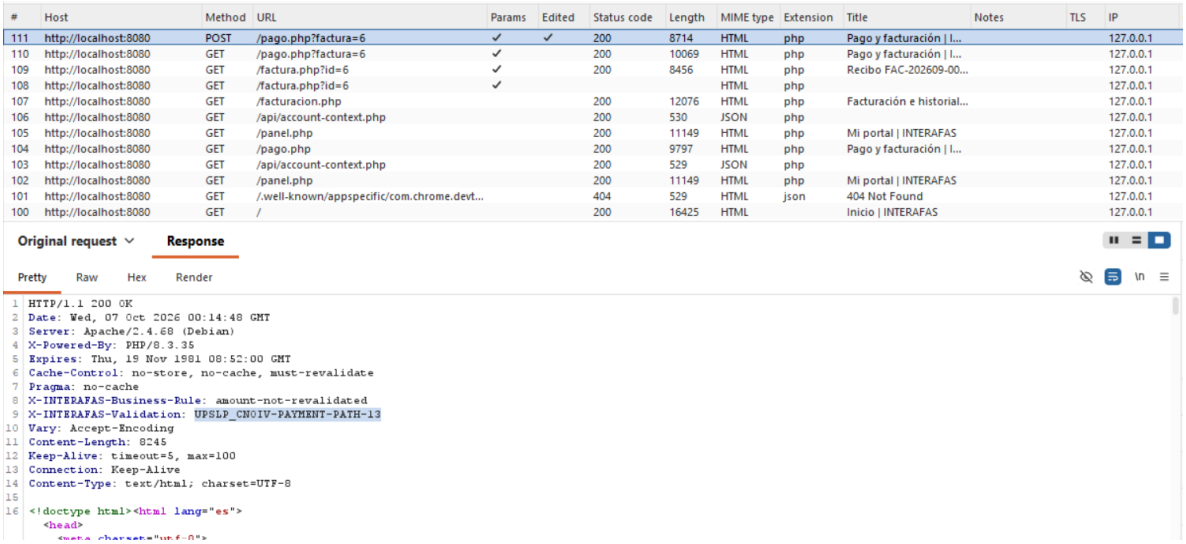
Causa raíz

El control de "importe fijo e inmodificable" existe únicamente en la capa de presentación (campo deshabilitado/calculado por JavaScript en el cliente). El endpoint pago.php confía en que el valor de monto recibido en el POST corresponde siempre al saldo total de la factura, sin recalcularlo ni validarlo del lado del servidor antes de marcar la operación como aplicada.

Impacto y riesgo

- Liquidación fraudulenta de adeudos: cualquier usuario autenticado puede saldar un recibo pagando una fracción arbitraria del monto real.
- Pérdida financiera directa para el organismo: al marcar la factura como Pagada con saldo en $0.00 pese a un pago parcial, se pierde la capacidad de cobrar la diferencia.
- El propio servidor documenta su falla (amount-not-revalidated), evidenciando que no es un descuido aislado sino una ausencia deliberada o no implementada de control server-side.

Evidencia / bandera obtenida



Mitigación recomendada

- Recalcular y validar en el servidor el importe exacto de la factura antes de aplicar cualquier pago, independientemente del valor recibido del cliente.
- Rechazar o marcar para revisión manual cualquier pago cuyo monto no coincida con el saldo real registrado en el backend.

Hallazgo RT-14: Validación Insuficiente de Relación Contrato-Proveedor (Broken Object-Level Relationship Authorization)

Clasificación	Broken Access Control – Relationship-Based Access Control (ReBAC) no implementado
CWE	CWE-639: Authorization Bypass Through User-Controlled Key
Referencia OWASP / estándar	OWASP Authorization Cheat Sheet – Contextual/Relationship Authorization
Componente / endpoint	validar-vinculo.php
Severidad	Media
Dónde se encontró	http://localhost:8080/validar-vinculo.php (formulario y POST de validación)

Comprobación y procedimiento de explotación

1. Se accedió a la sección de Contrataciones, opción "Validar vínculo", que permite confirmar que un proveedor está asociado a un contrato específico. Con una combinación real, el sistema respondió "vínculo vigente".

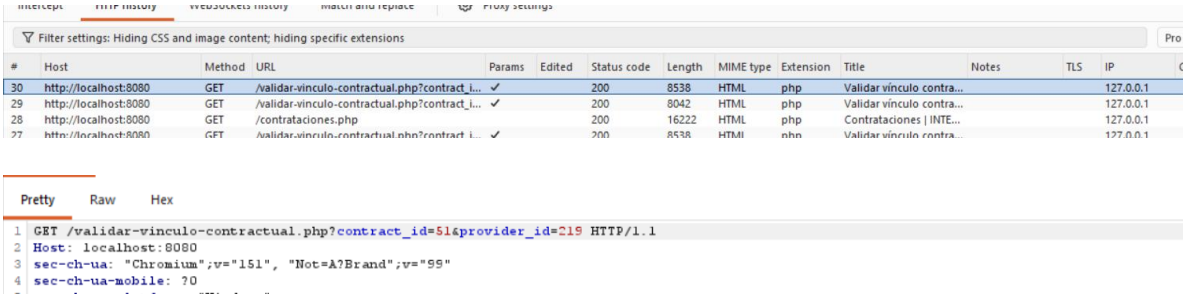


2. Se capturó con Burp Suite la solicitud de validación, identificando los parámetros contract_id=51 y provider_id=171.



3. Se consultó por separado el padrón público de proveedores y se identificó el proveedor con ID 219, activo pero sin relación conocida con el contrato bajo prueba.

4. En Burp Suite Repeater se reenvió la solicitud conservando el contract_id original y sustituyendo únicamente provider_id por 219.



5. El servidor respondió 200 OK con el mismo mensaje de éxito, sin rechazar la combinación pese a que el proveedor 219 no corresponde al contrato consultado, incluyendo la cabecera X-INTERAFAS-Relationship-Control: relationship-not-checked.



Causa raíz

El endpoint validar-vinculo.php valida dos condiciones independientes (existencia y vigencia del contrato, existencia y vigencia del proveedor) pero nunca consulta una tabla de asociación real que confirme que ambos registros están efectivamente enlazados entre sí.

Impacto y riesgo

- Falsificación de relaciones contractuales: cualquier usuario puede obtener confirmación oficial de un vínculo que no existe en la realidad.
- Riesgo de fraude documental y reputacional: puede usarse como respaldo aparentemente legítimo en auditorías, licitaciones o trámites.

Evidencia / bandera obtenida



Mitigación recomendada

- Validar en el backend, contra una tabla de asociación real (contrato_proveedor), que la relación declarada efectivamente existe antes de responder "vínculo vigente".
- Eliminar la cabecera de diagnóstico interno (X-INTERAFAS-Relationship-Control) de las respuestas públicas.

Hallazgo RT-15: Exposición de metadatos de diagnóstico en endpoint de estado de infraestructura

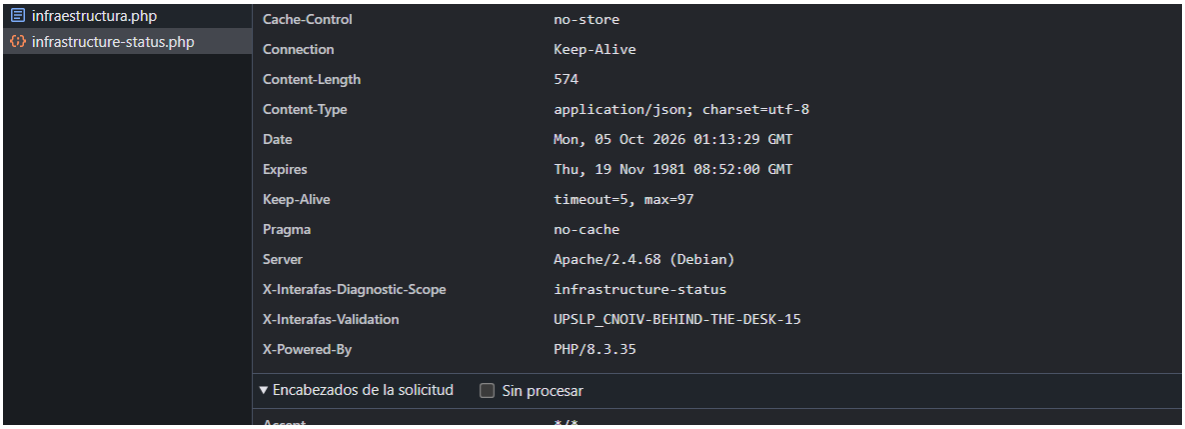
Clasificación	Information Disclosure en API de monitoreo
CWE	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
Referencia OWASP / estándar	OWASP A05:2021 – Security Misconfiguration
Componente / endpoint	/api/infrastructure-status.php
Severidad	Media
Dónde se encontró	GET /api/infrastructure-status.php

Comprobación y procedimiento de explotación

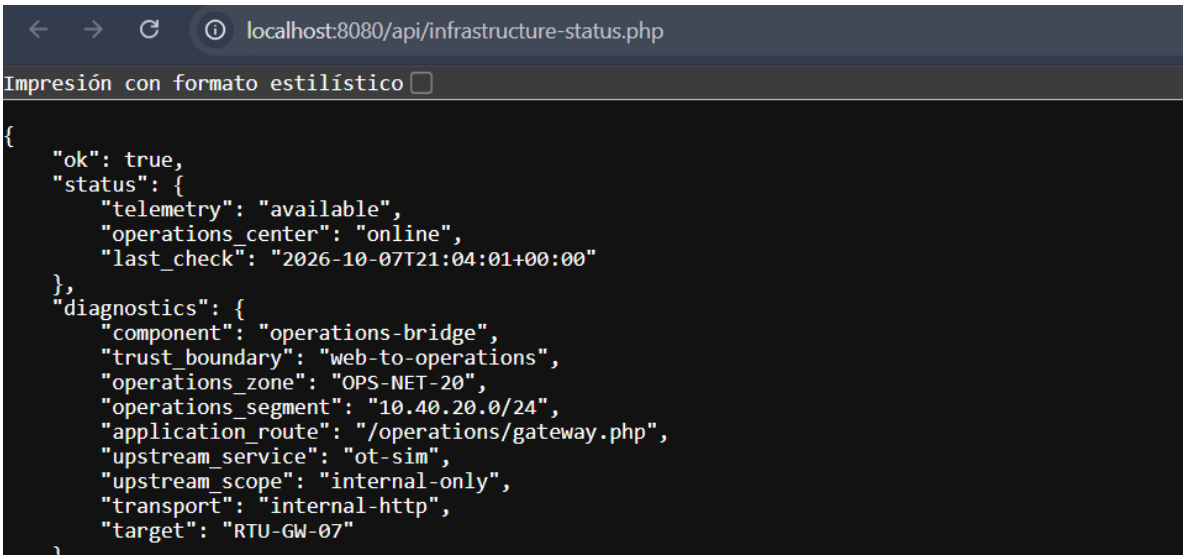
1. Se navegó a la sección "Infraestructura estratégica" del portal y se identificó un indicador visual que actualiza automáticamente el estado de integración del Centro de Operaciones.

2. Se abrieron las DevTools (F12 → Network, filtro XHR/Fetch) y se localizó la solicitud periódica que alimenta dicho indicador.

3. En lugar de quedarse con la vista resumida, se inspeccionó la pestaña Response para ver el cuerpo JSON completo devuelto por el servidor.



4. Se comparó el contenido total del JSON contra lo realmente renderizado en pantalla, confirmando que la interfaz solo consume el bloque status, mientras el servidor también envía un bloque diagnostics que nunca se muestra.



5. Se revisaron los encabezados HTTP, encontrando X-INTERAFAS-Validation: UPSLP_CNOIV-BEHIND-THE-DESK-15.

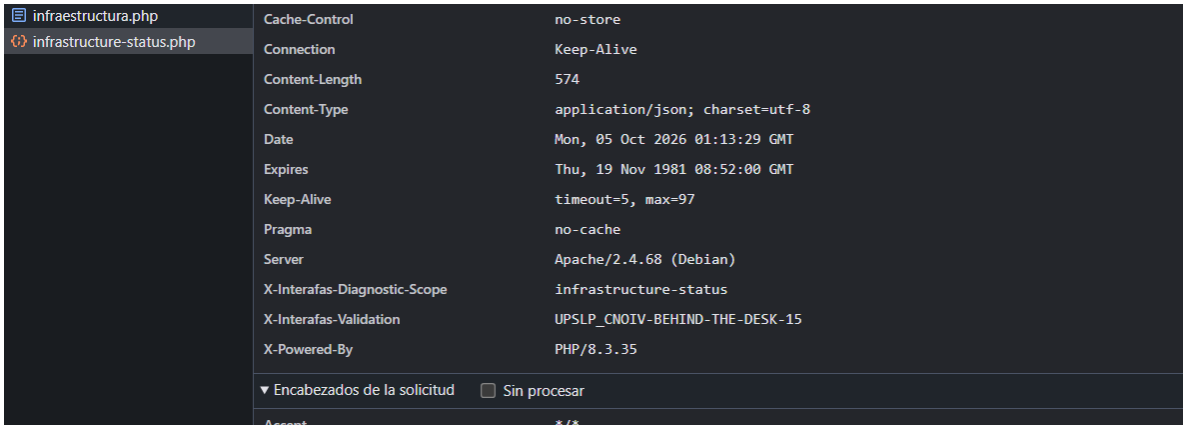
Causa raíz

El endpoint de estado de infraestructura devuelve un objeto JSON mucho más extenso del necesario para la funcionalidad visible, incluyendo un bloque diagnostics con metadatos técnicos internos (nombre del servicio puente, zona y segmento de red operacional, ruta de gateway, nombre del servicio upstream, identificador del dispositivo objetivo) que nunca se renderizan en pantalla.

Impacto y riesgo

- Fuga de información que reduce el esfuerzo de reconocimiento de un atacante, entregando gratuitamente la topología interna: zona, segmento CIDR, nombres de servicios, ruta de gateway e identificador del dispositivo OT objetivo.
- Especialmente sensible por tratarse de infraestructura relacionada con tecnología operacional (OT/ICS), donde el descubrimiento de activos suele ser el primer paso hacia ataques dirigidos a sistemas de control industrial.
- Sienta las bases (zona OPS-NET-20, segmento 10.40.20.0/24, ruta /operations/gateway.php) para la cadena de ataque explotada en los Hallazgos 16 a 20.

Evidencia / bandera obtenida



Mitigación recomendada

- Devolver únicamente los campos estrictamente necesarios para la funcionalidad visible (status.telemetry, status.operations_center).
- Eliminar o mover a un canal de logging interno, no accesible por HTTP, el bloque diagnostics.

- Segmentar explícitamente los endpoints de monitoreo interno de los endpoints públicos del portal.

Hallazgo RT-16: Bypass de control de acceso mediante falsificación de X-Forwarded-For (IP Spoofing)

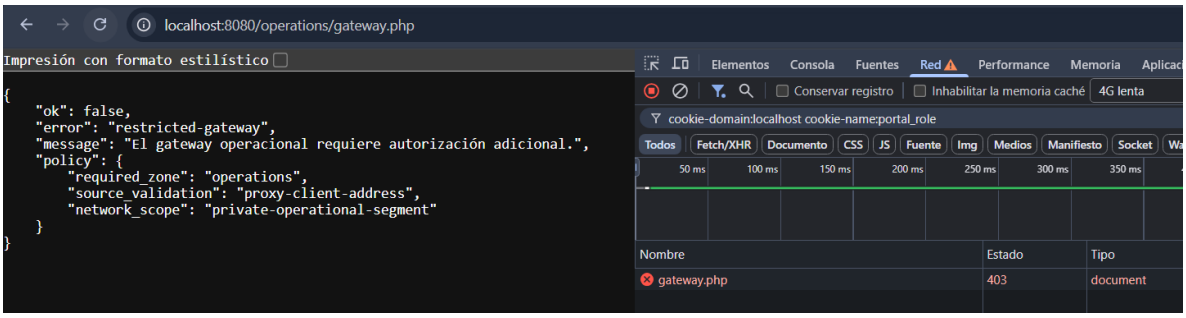
Clasificación	Broken Access Control – Bypass de segmentación de red
CWE	CWE-290: Authentication Bypass by Spoofing
Referencia OWASP / estándar	OWASP A01:2021 – Broken Access Control
Componente / endpoint	/operations/gateway.php
Severidad	Crítica
Dónde se encontró	GET /operations/gateway.php

Comprobación y procedimiento de explotación

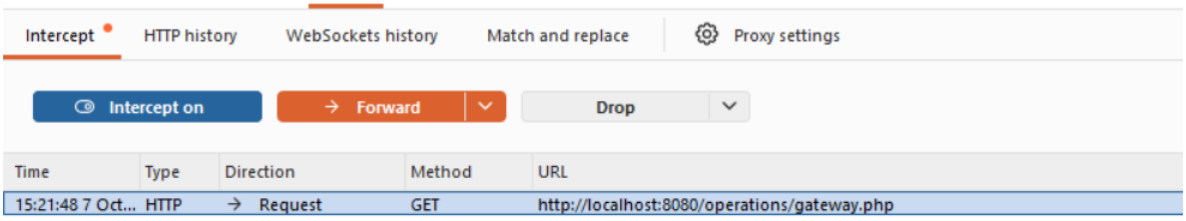
1. Se retomó el endpoint /operations/gateway.php, identificado en el Hallazgo 15 como la ruta que actúa de puente hacia la zona operacional OPS-NET-20 (10.40.20.0/24).



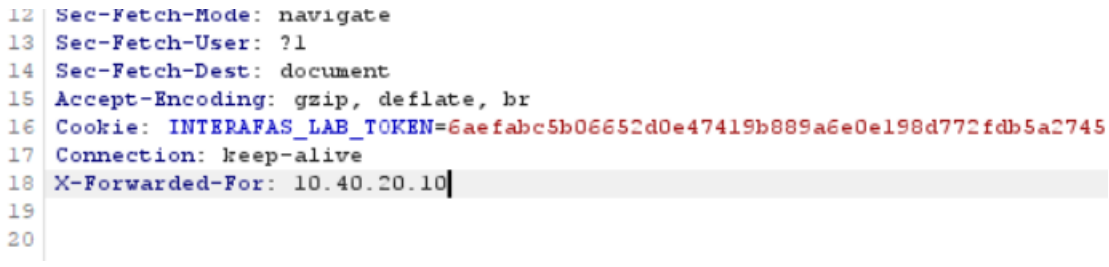
2. Se solicitó el endpoint sin modificaciones, obteniendo 403 Forbidden con un cuerpo JSON que declaraba la política de acceso y el campo source_validation: proxy-client-address, indicando que el servidor valida una dirección reportada por un encabezado de proxy, no la conexión TCP real.

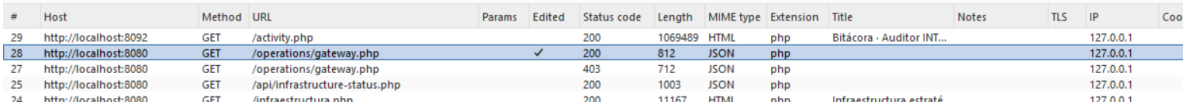


3. Usando Burp Suite con Intercept activado, se interceptó la petición original (con las cookies de sesión intactas) y se añadió el encabezado X-Forwarded-For: 10.40.20.10, una dirección dentro del segmento operacional descubierto en el Hallazgo 15.



4. Se reenvió la petición modificada y el servidor respondió 200 OK, confirmando el bypass del control de red.





Causa raíz

El gateway restringe el acceso a clientes que, según su política, deben pertenecer al segmento de red operacional privado. Sin embargo, en lugar de determinar el origen de la petición a partir de la

conexión TCP real, el servidor confía en el valor del encabezado HTTP X-Forwarded-For, controlado íntegramente por quien envía la solicitud.

Impacto y riesgo

- Rompe por completo la segmentación de red declarada por la aplicación: un control pensado para que solo sistemas dentro de la red OT puedan interactuar con el gateway resulta trivialmente evadible desde el portal web.
- No requiere comprometer la red interna ni pivotear realmente; la evasión ocurre completamente en la capa de aplicación.
- En el contexto de infraestructura OT/ICS (MITRE ATT&CK ICS T0886 – Remote Services), una frontera de confianza mal implementada entre la zona IT y OT es particularmente crítica.

Evidencia / bandera obtenida



Mitigación recomendada

- No usar X-Forwarded-For (ni X-Real-IP, Client-IP) como mecanismo de autorización, salvo cuando el servidor esté configurado para confiar en él únicamente desde proxies internos conocidos (p. ej. mod_remoteip en Apache).
- Si existe una arquitectura de proxy inverso legítima, configurarla para sobrescribir cualquier X-Forwarded-For enviado por el cliente en lugar de anexarlo sin validar.

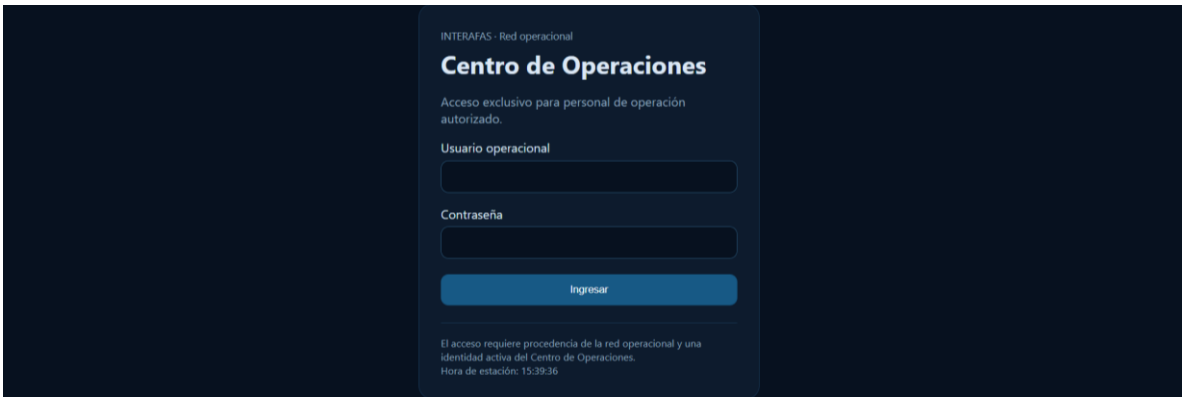
- Preferir mecanismos de control de acceso a nivel de infraestructura (firewall, segmentación real de red, mTLS entre zonas) en lugar de encabezados HTTP.
- Aplicar defensa en profundidad: el endpoint no debería depender de un único control para proteger el acceso a una zona operacional sensible.

Hallazgo RT-17: Autenticación faltante en servicio de telemetría del HMI

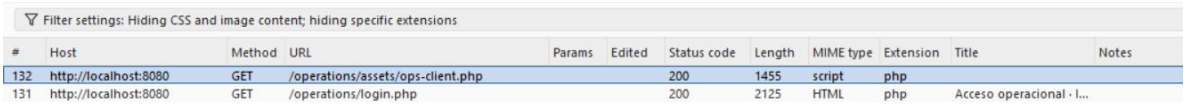
Clasificación	Missing Authentication for Critical Function / Missing Authorization
CWE	CWE-306: Missing Authentication for Critical Function; CWE-862: Missing Authorization
Referencia OWASP / estándar	OWASP Authentication Cheat Sheet
Componente / endpoint	/operations/telemetry.php
Severidad	Crítica
Dónde se encontró	GET /operations/telemetry.php

Comprobación y procedimiento de explotación

1. Se retomó la ruta operacional revelada por el gateway en el Hallazgo 16 (/operations/login.php), confirmando, con el header X-Forwarded-For persistente, que conduce al formulario legítimo de acceso del Centro de Operaciones.



2. Al inspeccionar el HTML de login.php se identificó que carga el script /operations/assets/ops-client.php, cliente JavaScript compartido por toda la aplicación operacional, que expone en texto plano el endpoint de telemetría.



Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes
132	http://localhost:8080	GET	/operations/assets/ops-client.php			200	1455	script	php		
131	http://localhost:8080	GET	/operations/login.php			200	2125	HTML	php	Acceso operacional · I...	

3. Se solicitó GET /operations/telemetry.php directamente, sin haber iniciado sesión en login.php, pero manteniendo el header X-Forwarded-For necesario para superar el gateway del Hallazgo 16.

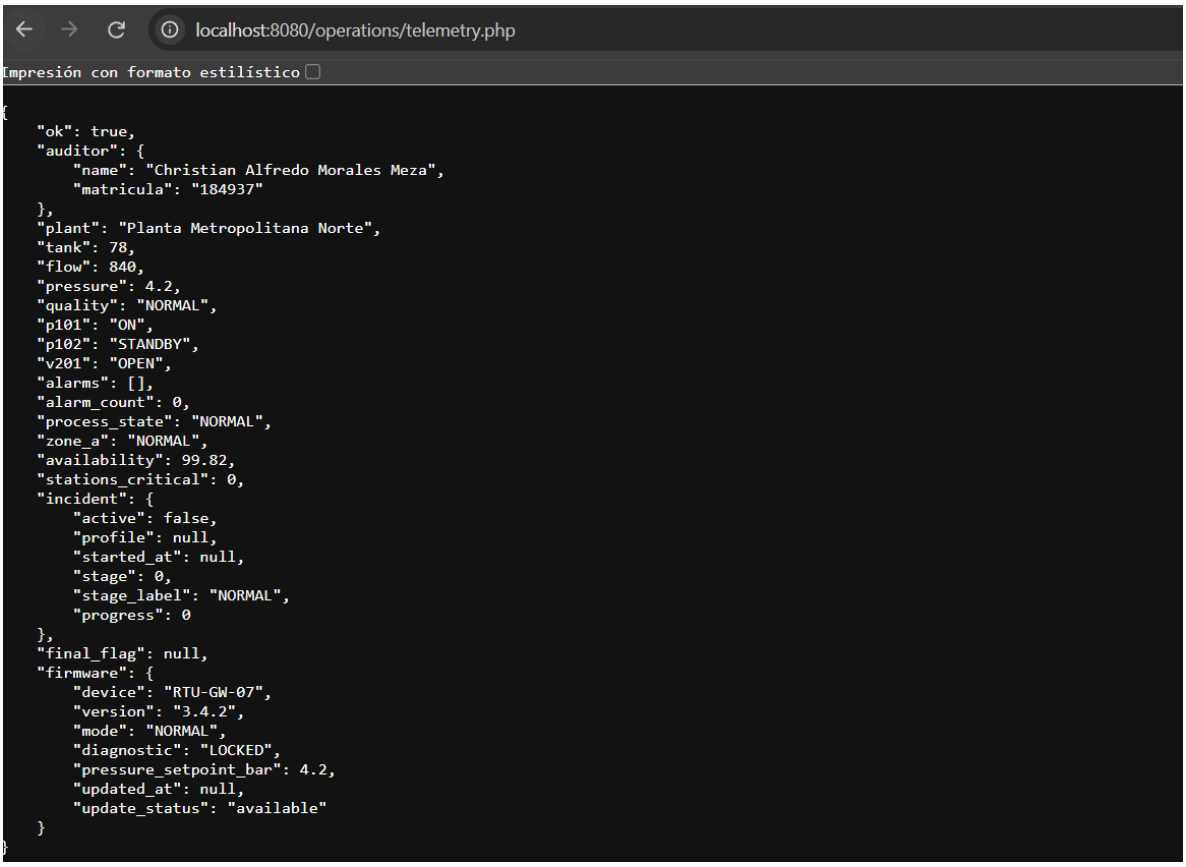


Request Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  Date: Wed, 07 Oct 2026 21:39:31 GMT
3  Server: Apache/2.4.68 (Debian)
4  X-Powered-By: PHP/8.3.35
5  Expires: Thu, 19 Nov 1981 08:52:00 GMT
6  Cache-Control: no-store
7  Pragma: no-cache
8  Vary: Accept-Encoding
9  Content-Length: 1105
10 Keep-Alive: timeout=5, max=99
11 Connection: Keep-Alive
12 Content-Type: application/javascript; charset=utf-8
13
14 window.INTERAFAS_OPS = Object.freeze({
15   telemetryEndpoint: '/operations/telemetry.php',
16   firmwareStatusEndpoint: '/operations/firmware-status.php',
17   assetContextEndpoint: '/operations/asset-context.php',
18   refreshInterval: 1000,
19   firmwareRefreshInterval: 30000
20 });
```

4. El servidor respondió 200 OK con el estado de proceso completo de la planta, confirmando que el endpoint de telemetría no exige la misma autenticación que la consola principal.



5. La respuesta incluyó las cabeceras X-INTERAFAS-Monitoring-Authorization: network-only y X-INTERAFAS-Operational-Session: missing, confirmando ambos hechos de forma explícita.

Causa raíz

El Centro de Operaciones protege su consola principal (login.php) con autenticación usuario/contraseña, pero el endpoint auxiliar que alimenta esa consola con datos en tiempo real (telemetry.php) no replica ese mismo control: responde con datos completos del proceso industrial a cualquier petición que haya superado el control de red del gateway, sin validar sesión de usuario autenticada. El servicio sustituyó la autenticación de aplicación por una autorización de red.

Impacto y riesgo

- Un atacante que únicamente evadió la restricción de red del Hallazgo 16, sin robar credenciales ni comprometer ninguna cuenta, obtiene visibilidad total y en tiempo real del estado de un proceso industrial (tanque, flujo, presión, válvulas, bombas, alarmas).

- Según NIST SP 800-82 Rev. 3, los servicios de soporte de un HMI requieren controles de acceso consistentes con la consola principal, incluso dentro de segmentos de red restringidos.
- Facilita reconocimiento previo a un ataque dirigido contra el proceso industrial.

Evidencia / bandera obtenida



Mitigación recomendada

- Exigir la misma sesión de usuario autenticada (Operational-Session) en telemetry.php que en la consola principal; nunca basar la autorización de un endpoint de datos sensibles solo en el origen de red.
- Aplicar el principio del REST Security Cheat Sheet: cada endpoint de una API debe validar autenticación y autorización de forma independiente.
- Revisar firmware-status.php y asset-context.php (también expuestos en el cliente JS compartido) bajo el mismo criterio.

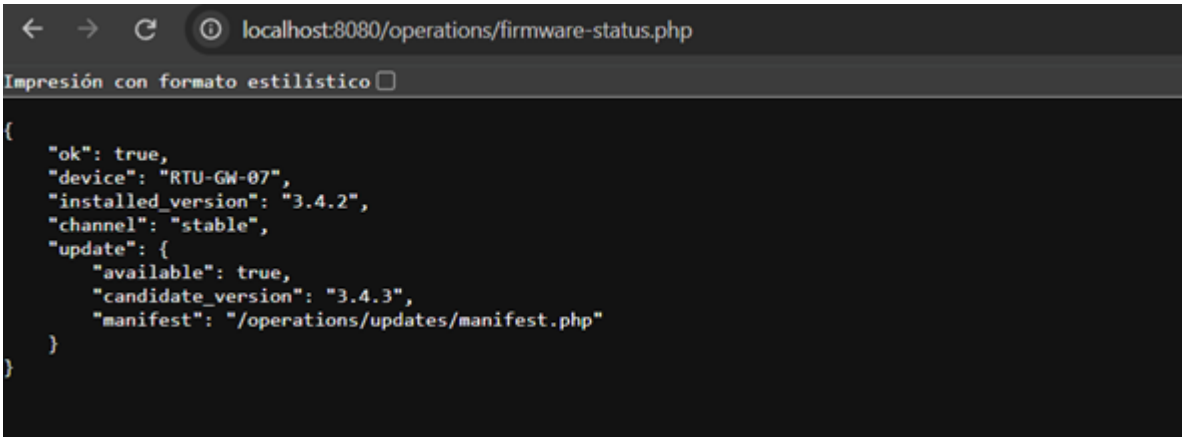
Hallazgo RT-18: Verificación insuficiente de autenticidad en el canal de actualización de firmware

Clasificación	Insufficient Verification of Data Authenticity
CWE	CWE-345: Insufficient Verification of Data Authenticity
Referencia OWASP / estándar	NIST SP 800-193 (Platform Firmware Resiliency Guidelines)

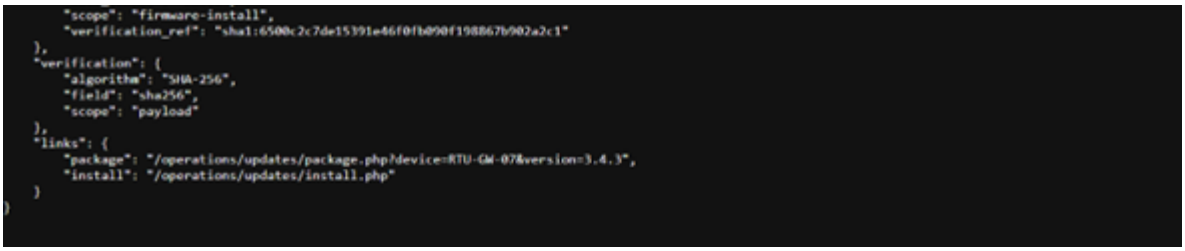
Componente / endpoint	/operations/updates/manifest.php, package.php, install.php
Severidad	Crítica
Dónde se encontró	GET /operations/updates/manifest.php; GET /operations/updates/package.php; POST /operations/updates/install.php

Comprobación y procedimiento de explotación

1. Se consultó firmware-status.php, declarado en el cliente JS compartido, el cual reveló la ruta del manifiesto de actualización.

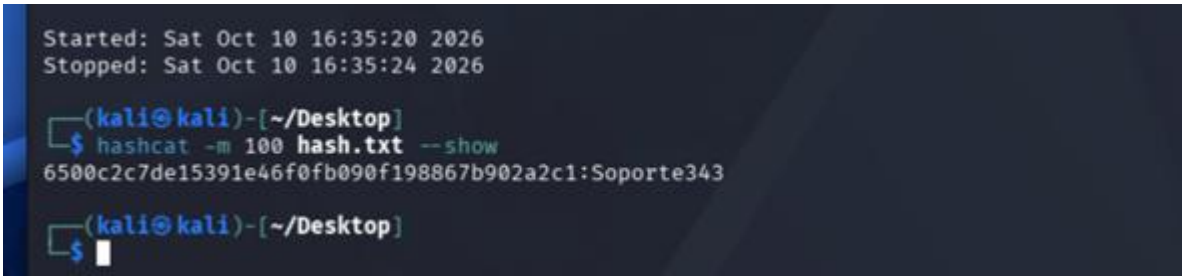


2. Se solicitó el manifiesto y se analizó el campo support.verification_ref, que contenía un valor con prefijo sha1: de 40 caracteres hexadecimales, sin salt acompañante: un SHA-1 crudo, patrón heredado inseguro.



3. Se intentó primero un ataque de diccionario genérico sin éxito; se construyeron después candidatos derivados del contexto del manifiesto (identidad de soporte, dispositivo, versión, build) con reglas de mutación de Hashcat.

4. El ataque con la regla dive.rule recuperó el candidato Soporte343, combinando el rol del usuario con el número de build de la versión candidata.



5. Se aplicó la credencial al esquema y alcance declarados (Basic Auth, scope firmware-install) contra package.php, obteniendo 200 OK y el paquete de firmware aprobado.



6. Se modificó únicamente el campo diagnostic (de LOCKED a UNLOCKED), se recalculó su SHA-256 de forma independiente, y se envió la variante mediante POST /operations/updates/install.php; el servidor respondió 200 OK, aceptando e instalando el contenido no aprobado.



```
Cookie: INTERAFAS_LAB_TOKEN=
6aefabc5b06652d0e47419b889a6e0e198d772fdb5a27457555399b1f5af014c; PHPSESSID=
d7e698273e69ac2299524ddf8d66b3ea
Connection: keep-alive
Authorization: Basic c29wb3J0ZS5vdDpTb3BvcnRlMzQz
X-Forwarded-For: 10.40.20.10
Content-Type: application/json
Content-Length: 182

{
     "device":"RTU-GW-07",
     "version":"3.4.3",
     "payload":"{\"mode\":\"NORMAL\",\"diagnostic\":\"UNLOCKED\"}",
     "sha256":
     "a0918623aedb0f0e440dc2315a9c6108762c70f6380c2bc0cbc1a41c3fd7caf"
}
```

Causa raíz

El canal de actualización de firmware implementa un control de integridad (verifica que el SHA-256 enviado coincida con el contenido del payload) pero carece de un control de autenticidad (nunca verifica que el paquete provenga realmente del emisor legítimo mediante una firma digital). El propio servidor documenta la distinción: X-INTERAFAS-Firmware-Verification: checksum-only y X-INTERAFAS-Signature-Verification: not-performed.

Impacto y riesgo

- El sistema confunde integridad (el contenido no fue corrompido en tránsito) con autenticidad (el contenido proviene de un emisor confiable), exactamente la distinción que advierte CWE-345.
- Cualquier actor con las credenciales del canal de mantenimiento, incluso obtenidas mediante cracking offline de un residuo criptográfico heredado, podría desplegar firmware arbitrario en un RTU de planta.

Evidencia / bandera obtenida

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Date: Sat, 10 Oct 2026 21:21:28 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
X-INTERAFAS-Firmware-Verification: checksum-only
X-INTERAFAS-Signature-Verification: not-performed
X-INTERAFAS-Validation: UPSLP_CN0IV-TRUST-THE-PACKAGE-18
Content-Length: 442
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: application/json; charset=utf-8

{
     "ok":true,
     "device":"RTU-GW-07",
     "version":"3.4.3",
     "verification":{
          "integrity":"passed",
          "algorithm":"SHA-256",
          "authenticity":"not-verified"
     },
     "firmware":{
          "device":"RTU-GW-07",
          "version":"3.4.3",
          "mode":"NORMAL",
          "diagnostic":"UNLOCKED",
          "pressure_setpoint_bar":4.2,
          "updated_at":1791667288
     }
```

Mitigación recomendada

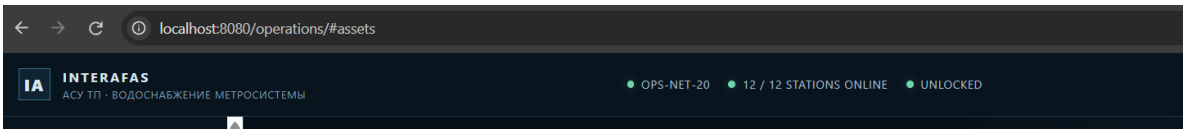
- Eliminar el verificador SHA-1 heredado del flujo de autenticación del canal de soporte; migrar a un esquema moderno (OAuth2/mTLS) con almacenamiento de credenciales conforme a OWASP Password Storage Cheat Sheet (bcrypt/Argon2 con salt).
- Implementar verificación de firma digital (p. ej. Ed25519 o RSA) sobre el paquete de firmware antes de aceptar cualquier actualización; el SHA-256 debe usarse únicamente para detectar corrupción accidental.

Hallazgo RT-19: Ausencia de límite de autorización en la cadena de dependencias de activos

Clasificación	Missing Authorization / Exceso de privilegio
CWE	CWE-862: Missing Authorization
Referencia OWASP / estándar	OWASP Authorization Cheat Sheet
Componente / endpoint	/operations/asset-context.php?asset=
Severidad	Alta
Dónde se encontró	GET /operations/asset-context.php?asset=<nombre_del_activo>

Comprobación y procedimiento de explotación

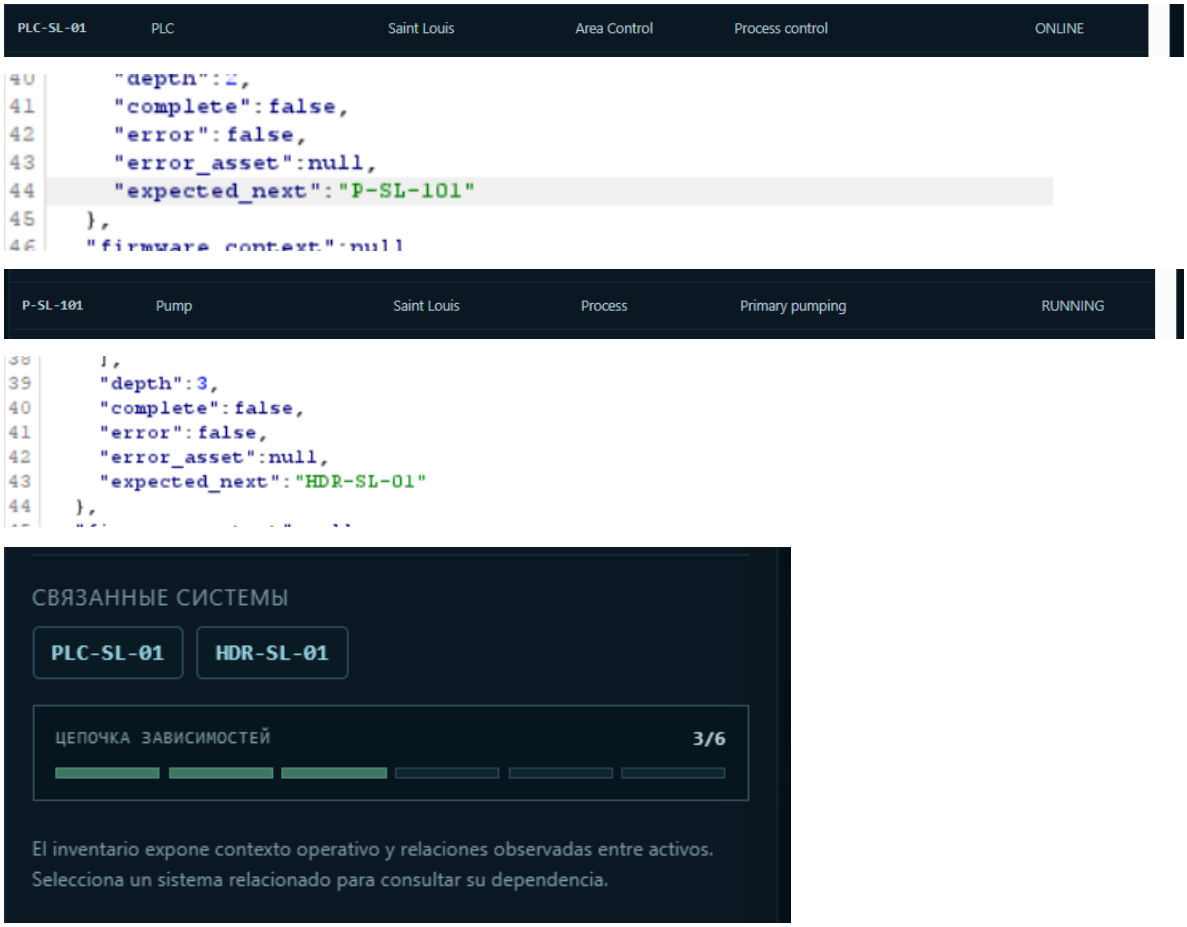
1. Se confirmó que la sesión de mantenimiento obtenida en el Hallazgo 18 (rol maintenance) seguía activa en el HMI.
2. Se navegó a la sección Assets y se confirmó en DevTools que seleccionar un activo dispara una petición a asset-context.php?asset=.



3. Se inspeccionó la respuesta JSON completa, identificando un objeto path con sequence_length, depth, visited y, crucialmente, un campo expected_next que indica el siguiente salto correcto de la cadena de dependencias.
4. Siguiendo únicamente los valores declarados en expected_next de cada respuesta, se recorrió la cadena completa de seis saltos (gateway → PLC → bomba → colector hidráulico → válvula de control → zona de servicio), validando en cada paso que el indicador de progreso avanzara.

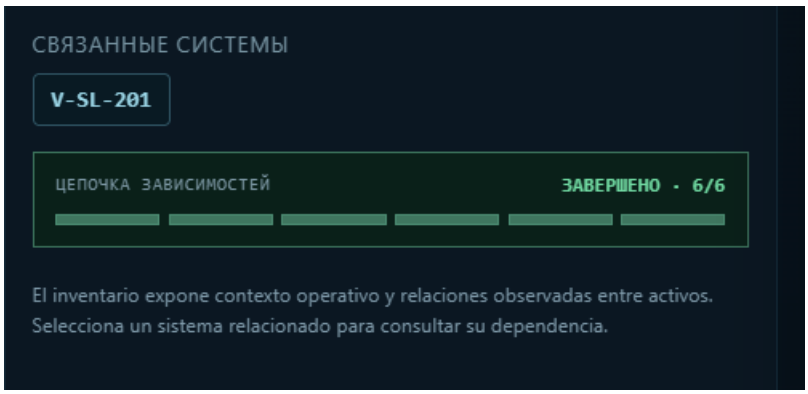
```
{
  "ok":true,
  "asset":"RTU-GW-07",
  "type":"RTU / Gateway",
  "station":"Metropolitan",
  "zone":"OT Edge",
  "function":"Remote operations gateway",
  "status":"ONLINE",
  "dependency_class":"UPSTREAM / CONTROL",
  "related":[
    "HMI-OPS-01",
    "BRS-01",
    "PLC-SL-01"
  ],
  "access":{
    "role":"maintenance",
    "scope":"maintenance-context",
    "server_enforced_dependency_boundary":false
  },
  "path":{
    "sequence_length":6,
    "visited":[
      "RTU-GW-07"
    ],
    "depth":1,
    "complete":false,
    "error":false,
    "error_asset":null,
    "expected_next":"PLC-SL-01"
  },
  "firmware_context":null
}
```


Captura del proceso seguido.



```
      "P-SL-101",
      "HDR-SL-01"
    ],
    "depth":4,
    "complete":false,
    "error":false,
    "error_asset":null,
    "expected_next":"V-SL-201"
  },
  "firmware_context":null
}
```

```
    "depth":5,
    "complete":false,
    "error":false,
    "error_asset":null,
    "expected_next":"ZONE-SL-A"
  },
  "firmware_context":null
}
```

5. En la respuesta final, el campo path.complete cambió a true con depth: 6, confirmando el recorrido íntegro; los encabezados de respuesta mostraron X-INTERAFAS-Authorization-Scope: exceeded.

Causa raíz

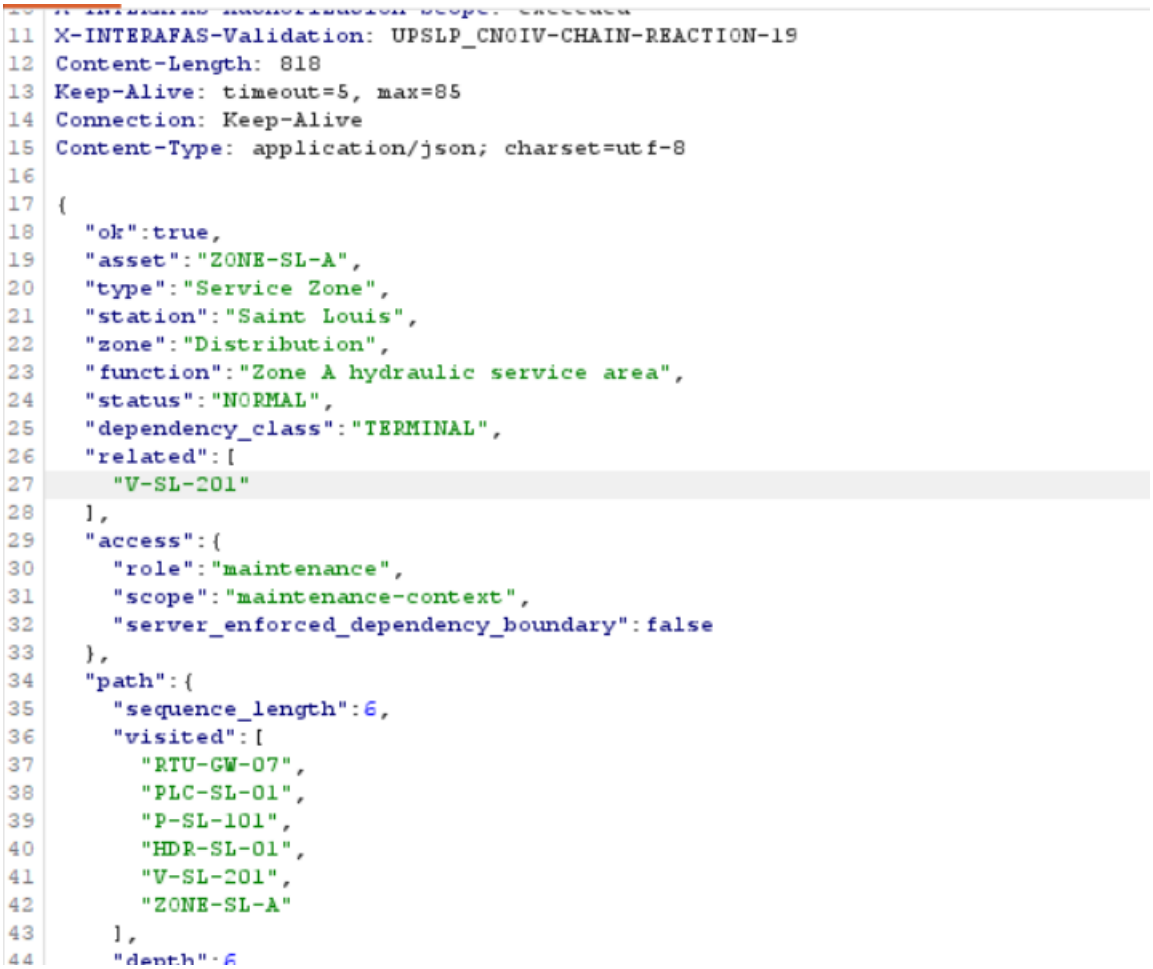
El servidor incluye en cada respuesta un campo access que declara el problema sin ambigüedad: nunca evaluó si la relación consultada debía estar permitida para un rol cuyo alcance declarado era firmware-install sobre un único dispositivo. El mismo campo apareció idéntico en las seis respuestas de la cadena.

Impacto y riesgo

- La sesión maintenance, cuyo alcance legítimo estaba limitado a la instalación de firmware de un único RTU, pudo enumerar sin restricción toda la topología de dependencias operacionales de una estación completa de la planta.

- Un atacante que solo comprometió una credencial de bajo privilegio puede, sin pivotear ni escalar privilegios, obtener un mapa de reconocimiento detallado de la arquitectura de control industrial completa.

Evidencia / bandera obtenida



```
X-INTERAFAS-Validation: UPSLP_CNOIV-CHAIN-REACTION-19
Content-Length: 818
Keep-Alive: timeout=5, max=85
Connection: Keep-Alive
Content-Type: application/json; charset=utf-8

{
  "ok":true,
  "asset":"ZONE-SL-A",
  "type":"Service Zone",
  "station":"Saint Louis",
  "zone":"Distribution",
  "function":"Zone A hydraulic service area",
  "status":"NORMAL",
  "dependency_class":"TERMINAL",
  "related":[
    "V-SL-201"
  ],
  "access":{
    "role":"maintenance",
    "scope":"maintenance-context",
    "server_enforced_dependency_boundary":false
  },
  "path":{
    "sequence_length":6,
    "visited":[
      "RTU-GW-07",
      "PLC-SL-01",
      "P-SL-101",
      "HDR-SL-01",
      "V-SL-201",
      "ZONE-SL-A"
    ],
    "depth":6
```

Mitigación recomendada

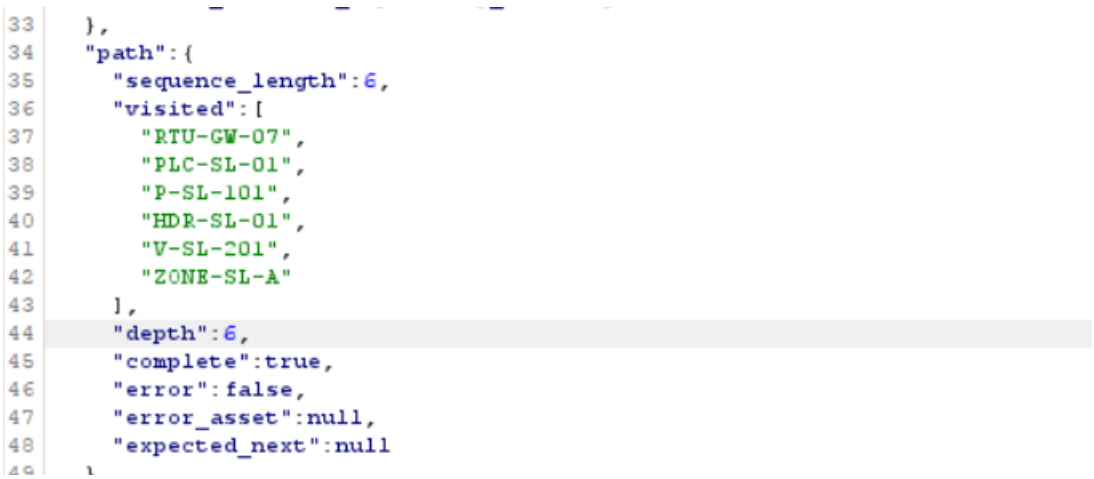
- Implementar control de autorización por solicitud (deny-by-default) en asset-context.php, validando en cada petición si el rol de la sesión tiene permiso explícito para esa relación entre activos.
- Establecer que el campo de frontera de dependencias refleje una restricción real aplicada en backend, no una mera sugerencia de interfaz (expected_next).

Hallazgo RT-20: Carga de firmware sin validación de límites operacionales de ingeniería

Clasificación	Improper Input Validation sobre parámetros de proceso industrial
CWE	CWE-345: Insufficient Verification of Data Authenticity
Referencia OWASP / estándar	MITRE ATT&CK ICS T0836 – Modify Parameter
Componente / endpoint	/operations/firmware.php
Severidad	Crítica
Dónde se encontró	GET /operations/firmware.php?backup=1 (descarga); POST /operations/firmware.php (carga)

Comprobación y procedimiento de explotación

1. Al completarse el Hallazgo 19 (cadena de dependencias, path.complete: true), se habilitó dinámicamente el menú Firmware en el HMI, antes inaccesible para la sesión maintenance.



2. Al consultar el activo BRS-01 en asset-context.php, la respuesta reveló las rutas exactas del canal de firmware y una advertencia explícita: los setpoints operacionales deben permanecer dentro de la línea base de ingeniería aprobada.

```
    "expected_next":"RTU-GW-07"
  },
  "firmware_context":{
    "device":"RTU-GW-07",
    "classification":"gateway-control-parameters",
    "channel":"/operations/firmware.php",
    "backup":"/operations/firmware.php?backup=1",
    "warning":"Operational setpoints must remain within the approved engineering baseline."
  }
}
```


3. Se descargó el backup original del firmware, confirmando 4.2 bar como el baseline aprobado de ingeniería para pressure_setpoint_bar.

RTU-GW-07-backup.json

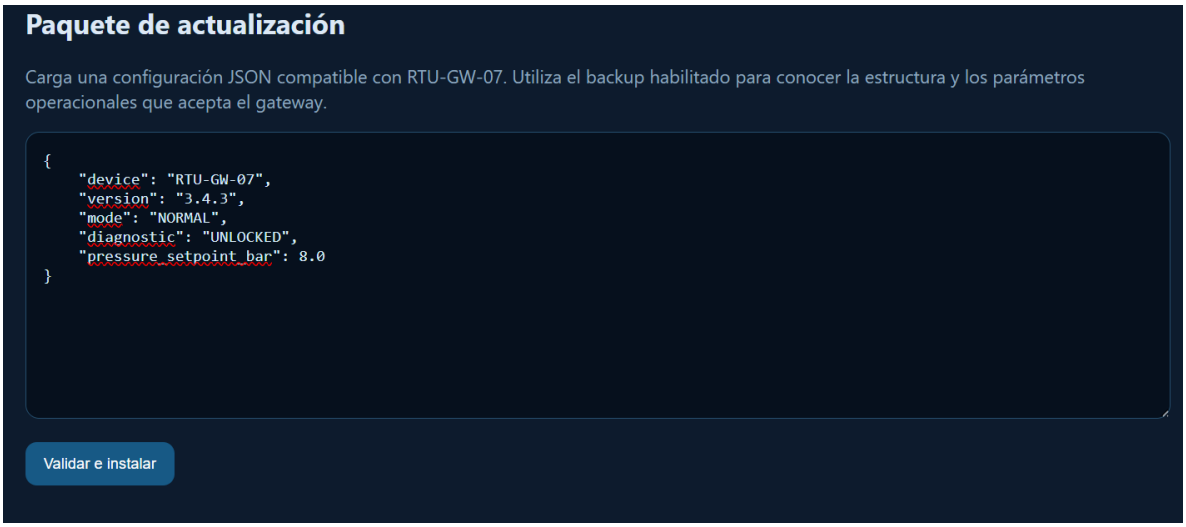
C: > Users > alfre > Downloads > {} RTU-GW-07-backup.json

```
{
    "device": "RTU-GW-07",
    "version": "3.4.3",
    "mode": "NORMAL",
    "diagnostic": "UNLOCKED",
    "pressure_setpoint_bar": 4.2
}
```


4. Se conservó una copia del backup original como evidencia y se creó una variante modificando únicamente pressure_setpoint_bar de 4.2 a 8, dejando intactos el resto de los campos.



5. Se cargó el JSON modificado mediante el formulario "Paquete de actualización"; fue aceptado sin ninguna validación de rango ni verificación de firma del emisor.



6. Al volver al dashboard principal se observó en tiempo real una cascada de deterioro del proceso: incremento de alarmas, caída de disponibilidad y propagación del estado crítico hasta alcanzar CATASTROPHIC STATE, apareciendo automáticamente la bandera del reto.

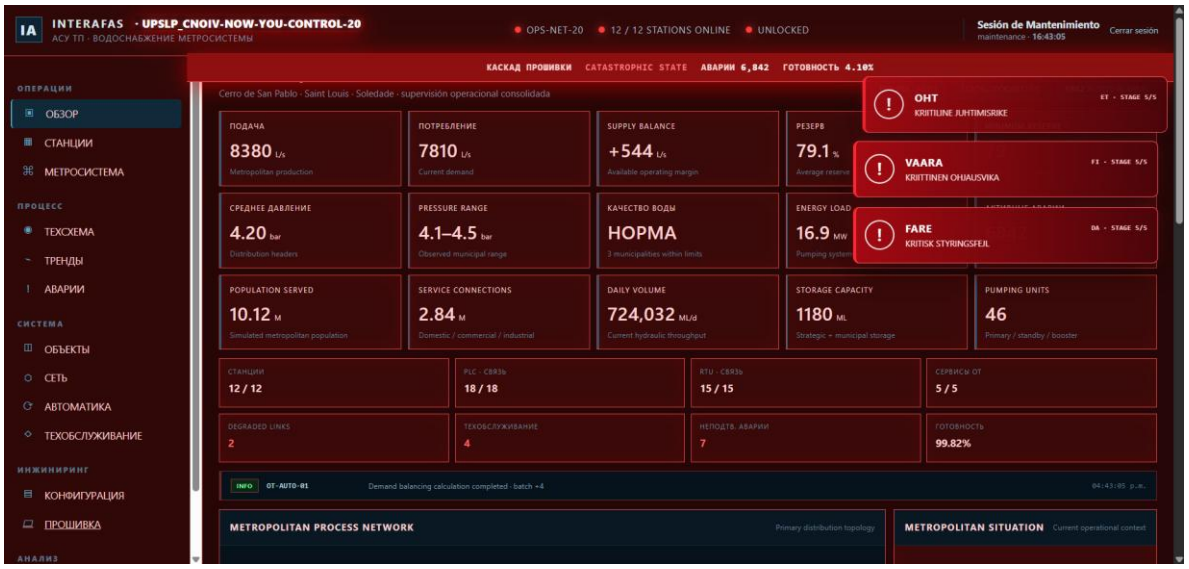
Causa raíz

El canal de actualización de firmware acepta un parámetro operacional crítico (pressure_setpoint_bar) dentro del mismo paquete JSON usado para metadatos de firmware, sin aplicar ninguna validación de rango contra el baseline de ingeniería aprobado. Un cambio de setpoint, que en un entorno real determina directamente el comportamiento físico de bombas y válvulas, se trata con el mismo nivel de confianza que un cambio cosmético de estado de diagnóstico.

Impacto y riesgo

- Culminación de la cadena de fallas de los Hallazgos 15 a 19: la ausencia de autenticidad en el canal de firmware y el exceso de privilegio del rol maintenance convergen en un impacto físico real sobre el proceso.
- Un atacante que solo comprometió una credencial de alcance limitado pudo alterar un parámetro de control de proceso hasta provocar una condición catastrófica simulada.
- Demuestra que la falta de separación entre "metadatos de firmware" y "parámetros operacionales de seguridad de proceso" es en sí misma una debilidad de diseño crítica.

Evidencia / bandera obtenida



Mitigación recomendada

- Separar completamente el canal de actualización de firmware del canal de configuración de parámetros operacionales de proceso (setpoints); nunca deben compartir el mismo endpoint ni nivel de confianza.
- Validar pressure_setpoint_bar y cualquier parámetro de control físico contra límites de ingeniería hard-coded en el dispositivo o en un sistema de gestión de cambios separado.

5. Cadena de Ataque

Si bien cada hallazgo fue documentado de forma individual, varios de ellos no son fallas aisladas sino eslabones de cadenas de explotación donde el resultado de un hallazgo habilita o facilita el siguiente. A continuación se reconstruyen las dos cadenas principales identificadas durante el ejercicio.

5.1 Cadena de reconocimiento y escalamiento en el portal web/API (RT-01 → RT-14)

Aunque los hallazgos RT-01 a RT-14 no dependen técnicamente unos de otros para ser explotados, en conjunto conforman una progresión lógica de riesgo que un atacante real seguiría:

- Fase de reconocimiento (RT-01, RT-02, RT-04, RT-05): artefactos de despliegue, metadatos de build y archivos de respaldo filtran nombres internos de servicios, estructura de la base de datos y tokens de prueba, sin necesidad de explotar ninguna lógica de la aplicación.
- Fase de control de acceso (RT-03, RT-06, RT-09, RT-10): el atacante, ya con una cuenta ciudadana básica (o incluso sin autenticarse, en el caso de RT-09), escala horizontal y verticalmente: accede a expedientes ajenos (RT-03), se convierte en administrador editando una cookie (RT-06), lee archivos arbitrarios del sistema (RT-09) y secuestra sesiones ajenas sin robar credenciales (RT-10).
- Fase de inyección y persistencia (RT-07, RT-08): con el conocimiento adquirido, el atacante extrae la base de datos completa mediante inyección SQL ciega (RT-07) y planta un payload persistente que se ejecuta contra cualquier visitante, incluyendo personal interno (RT-08).
- Fase de API y lógica de negocio (RT-11, RT-12, RT-13, RT-14): el atacante descubre endpoints de API no documentados (RT-11), los explota para acceder a cuentas ajenas (RT-12), y abusa de la lógica de negocio para liquidar pagos de forma fraudulenta (RT-13) y falsificar relaciones contractuales (RT-14).
- El hallazgo RT-15 actúa como puente hacia la segunda cadena: la fuga de metadatos de diagnóstico del endpoint de infraestructura revela, por primera vez, la existencia y topología de la zona operacional OT/ICS.

5.2 Cadena de compromiso del entorno OT/ICS (RT-15 → RT-20)

Esta es la cadena de mayor criticidad del ejercicio, documentada de forma explícita y secuencial durante las pruebas, en la que cada reto depende directamente de la evidencia o del acceso obtenido en el anterior:

- RT-15 — Reconocimiento: la fuga de metadatos de diagnóstico revela la topología de la zona operacional (OPS-NET-20, segmento 10.40.20.0/24, ruta del gateway, nombre del dispositivo objetivo RTU-GW-07).

- RT-16 — Bypass de segmentación: con la dirección del segmento operacional ya conocida, se falsifica el encabezado X-Forwarded-For para evadir el control de acceso de red del gateway, obteniendo acceso a la superficie operacional.
- RT-17 — Autenticación faltante: una vez dentro del segmento (de forma falsificada), se descubre que el servicio de telemetría del HMI no exige autenticación de sesión propia, exponiendo el estado completo del proceso industrial.
- RT-18 — Compromiso del canal de firmware: a partir de pistas observadas en la telemetría, se identifica y crackea offline una credencial heredada (SHA-1 sin sal) que otorga acceso Basic Auth al canal de actualización de firmware, el cual valida integridad pero nunca autenticidad, permitiendo instalar un paquete modificado.
- RT-19 — Exceso de privilegio: la sesión de mantenimiento obtenida en RT-18 permite recorrer, sin límite de autorización, toda la cadena de dependencias de activos de una estación completa de la planta.
- RT-20 — Impacto físico: completar la cadena de activos habilita el menú de Firmware en el HMI, a través del cual se carga un parámetro operacional (presión de consigna) fuera del rango de ingeniería aprobado, provocando una condición catastrófica simulada sobre el proceso de suministro de agua.

6. Conclusiones Generales y Recomendaciones Prioritarias

6.1 Postura de seguridad general

El Portal INTERAFAS, en su estado evaluado, presenta deficiencias de seguridad en prácticamente todas las capas analizadas: higiene de despliegue, control de acceso a nivel de objeto y de función, validación de entrada, gestión de sesión, lógica de negocio y, de forma especialmente crítica, la segmentación y los controles de autenticidad entre la red de TI y la red de tecnología operacional. La severidad agregada (9 hallazgos críticos, 7 altos y 4 medios) y la facilidad de explotación de la mayoría de los hallazgos —reproducibles con herramientas de desarrollador estándar del navegador y un proxy de interceptación gratuito— sitúan al sistema en un nivel de riesgo que requiere atención inmediata antes de cualquier despliegue en un entorno de producción real.

6.2 Recomendaciones prioritarias (quick wins)

- Eliminar inmediatamente del document root público cualquier artefacto de despliegue, archivo de respaldo o endpoint de metadatos de build (RT-01, RT-02, RT-04).
- Nunca basar decisiones de autorización en datos controlados por el cliente (cookies de rol, encabezados X-Forwarded-For, campos de formulario deshabilitados) sin revalidación equivalente en el servidor (RT-06, RT-13, RT-14, RT-16).
- Implementar autorización a nivel de objeto (verificación de propiedad) en todos los endpoints que reciban un identificador de recurso como parámetro, tanto en el portal como en la API (RT-03, RT-09, RT-12).
- Adoptar consultas preparadas de forma universal y codificación de salida contextual para eliminar las clases de inyección SQL y XSS (RT-07, RT-08).
- Separar de forma definitiva el canal de actualización de firmware del canal de parámetros operacionales de proceso, e implementar verificación de firma digital además del control de integridad existente (RT-18, RT-20).

6.3 Recomendación estratégica

Más allá de la corrección puntual de cada hallazgo, se recomienda a INTERAFAS establecer un programa formal de gestión de vulnerabilidades y gobernanza de seguridad de la información, alineado a ISO/IEC 27001, que incluya: un inventario vivo de activos y endpoints (API e infraestructura OT), un proceso de higiene de release verificado automáticamente en el pipeline de CI/CD, pruebas de seguridad recurrentes (SAST/DAST y pentesting periódico) integradas al ciclo de desarrollo, y una segmentación de red entre TI y OT reforzada con controles a nivel de infraestructura (firewall, mTLS) en lugar de encabezados HTTP. La cadena RT-15→RT-20 demuestra que, sin gobernanza transversal, fallas individualmente moderadas pueden converger en un incidente de seguridad con consecuencias físicas sobre infraestructura crítica.